

ULTIMATE CYBERSECURITY MASTER BLUEPRINT 2026-2027

Volume 3 — Daily Curriculum: Months 5-8

112 daily cards for core security, web/API, ethical testing and blue team

Edition: Volume 3
Resource verification date: 2026-10-27
Plan window: 2026-10-27 to 2027-10-26 (shift dates if you start later)
System: 365 days, 12 academic months, 52 weeks + 1 graduation day
Profile: BS CS student in Pakistan; free/high-value resources; safe authorized labs

Academic-style self-study manual. No employment, salary, visa, certification or top-1% guarantee.

Table of contents

Month 05 — Core security, cryptography, identity, risk and controls 3
Month 05 · Week 1 · daily cards 4
Month 05 · Week 2 · daily cards 11
Month 05 · Week 3 · daily cards 18
Month 05 · Week 4 · daily cards 25

Month 06 — Web security, API security and secure coding 32
Month 06 · Week 1 · daily cards 33
Month 06 · Week 2 · daily cards 40
Month 06 · Week 3 · daily cards 47
Month 06 · Week 4 · daily cards 54

Month 07 — Ethical testing, vulnerability assessment and authorized labs 61
Month 07 · Week 1 · daily cards 62
Month 07 · Week 2 · daily cards 69
Month 07 · Week 3 · daily cards 76
Month 07 · Week 4 · daily cards 83

Month 08 — Blue team, SOC, logs, SIEM and incident response 90
Month 08 · Week 1 · daily cards 91
Month 08 · Week 2 · daily cards 98
Month 08 · Week 3 · daily cards 105
Month 08 · Week 4 · daily cards 112

Month 05 — Core security, cryptography, identity, risk and controls

Days D113-D140. Each day has the same 13-field structure. Use the Core, Standard or Intensive track; the learning objective does not change. Day 7 of each week is lighter by design.

Week	Daily topics
Week 1	D1: CIA triad, non-repudiation and security trade-offs D2: AAA, least privilege and defense in depth D3: Threats, vulnerabilities, exploits, risk and impact D4: Attack surfaces and data-flow threat modelling D5: Security architecture and control categories D6: Security policies, standards, procedures and baselines D7: Weekly core-security review and risk practical
Week 2	D1: Hash functions and password storage D2: Symmetric encryption, block modes and key management D3: Public-key cryptography, key exchange and digital signatures D4: TLS, certificates and chain of trust D5: Identity, federation, SSO and MFA D6: IAM lifecycle and privilege management D7: Weekly cryptography and identity review
Week 3	D1: Endpoint, network, application and data security controls D2: Patch and vulnerability management lifecycle D3: Phishing defense and security awareness D4: Incident response lifecycle and tabletop exercise D5: Business continuity, disaster recovery and backup validation D6: GRC frameworks and legal-obligation distinctions D7: Weekly controls, GRC and incident response review
Week 4	D1: Privacy by design and data classification D2: Security architecture review of the capstone D3: Certification readiness without exam obsession D4: Month 5 capstone: security control baseline D5: Month 5 practical examination and milestone gate D6: Monthly review, gap repair and Month 6 preview D7: Spaced revision, recovery and readiness check

> **Gate:** score the Month 5 assessment using the 100-point rubric in Volume 6. If score <70 or safety <9/10, follow the six-step repair protocol before advancing.

Month 05 · Week 1 · daily cards

D113 · M05W1D1 · CIA triad, non-repudiation and security trade-offs

Phase: Academic month · **Optional date:** 2027-02-16 · **Domain resources:** F04 / C01

1. Day / sequence	Global Day 113 of 365; calendar-free M05W1D1; optional date 2027-02-16.
2. Exact topic	CIA triad, non-repudiation and security trade-offs
3. Exact subtopics	Confidentiality, integrity, availability, authenticity, non-repudiation, usability and cost/benefit
4. Learning objective	Classify controls by the property they protect and identify trade-offs
5. Primary lecture / reading + direct URL	CS50's Introduction to Cybersecurity `https://cs50.harvard.edu/cybersecurity/` **Type:** University course · **Access:** Free OCW; paid edX verified certificate optional
6. Exact section / lesson locator	CS50 Cybersecurity Week 0-1 notes; F04 course home links to Week 0 and Week 1 pages. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write ten control examples from your lab and label primary/secondary CIA effects plus one usability cost. **2.** Standard (~2 h): Write ten control examples from your lab and label primary/secondary CIA effects plus one usability cost. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write ten control examples from your lab and label primary/secondary CIA effects plus one usability cost. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	cia-matrix.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can encrypting backups improve confidentiality but harm availability if keys are lost? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Every label is justified and at least three trade-offs are concrete Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CS50 Cybersecurity Week 0-1 notes; F04 course home links to Week 0 and Week 1 pages"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup CS50's Introduction to Cybersecurity (official YouTube playlist); write a five-line correction; retest next morning with a new 10-minute problem.

D114 · M05W1D2 · AAA, least privilege and defense in depth

Phase: Academic month · **Optional date:** 2027-02-17 · **Domain resources:** C01 / C06

1. Day / sequence	Global Day 114 of 365; calendar-free M05W1D2; optional date 2027-02-17.
2. Exact topic	AAA, least privilege and defense in depth
3. Exact subtopics	Identification, authentication, authorization, accounting, least privilege, separation of duties, layered controls and fail-safe defaults
4. Learning objective	Design layered access control for a small lab service
5. Primary lecture / reading + direct URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/` **Type:** Course index · **Access:** Free videos; paid notes/practice exams optional
6. Exact section / lesson locator	Professor Messer SY0-701 course index, objectives 1.2 and 3.3; use exact objective videos. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Model three layers of controls for a local web app, remove one layer in a thought experiment and describe the impact. **2.** Standard (~2 h): Model three layers of controls for a local web app, remove one layer in a thought experiment and describe the impact. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Model three layers of controls for a local web app, remove one layer in a thought experiment and describe the impact. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	aaa-design.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is logging part of accountability rather than authentication? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Diagram clearly separates identity, permission and evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Professor Messer SY0-701 course index, objectives 1.2 and 3.3; use exact objective videos"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Professor Messer SY0-701 Security+ official playlist; write a five-line correction; retest next morning with a new 10-minute problem.

D115 · M05W1D3 · Threats, vulnerabilities, exploits, risk and impact

Phase: Academic month · **Optional date:** 2027-02-18 · **Domain resources:** C26 / C06

1. Day / sequence	Global Day 115 of 365; calendar-free M05W1D3; optional date 2027-02-18.
2. Exact topic	Threats, vulnerabilities, exploits, risk and impact
3. Exact subtopics	Threat actor, capability, intent, vulnerability, exploit, asset, likelihood, impact, risk and residual risk
4. Learning objective	Decompose a news-style incident into precise risk language
5. Primary lecture / reading + direct URL	NIST SP 800-30 Revision 1 `https://csrc.nist.gov/pubs/sp/800/30/r1/final` **Type:** Official risk guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-30, risk model, threat sources and risk determination sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Analyze one synthetic scenario, fill a risk register with five entries, and explain why exploitability alone is not business risk. **2.** Standard (~2 h): Analyze one synthetic scenario, fill a risk register with five entries, and explain why exploitability alone is not business risk. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Analyze one synthetic scenario, fill a risk register with five entries, and explain why exploitability alone is not business risk. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	risk-register.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: How can a low-severity bug be high risk in a specific environment? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All terms are used correctly and risk ranking includes context Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-30, risk model, threat sources and risk determination sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D116 · M05W1D4 · Attack surfaces and data-flow threat modelling

Phase: Academic month · **Optional date:** 2027-02-19 · **Domain resources:** C17 / A08

1. Day / sequence	Global Day 116 of 365; calendar-free M05W1D4; optional date 2027-02-19.
2. Exact topic	Attack surfaces and data-flow threat modelling
3. Exact subtopics	Assets, trust boundaries, data flows, entry points, privilege levels, STRIDE and misuse cases
4. Learning objective	Draw a defensible threat model for a system you own
5. Primary lecture / reading + direct URL	OWASP Threat Modeling community page `https://owasp.org/www-community/Threat_Modeling` **Type:** Reference/process · **Access:** Free
6. Exact section / lesson locator	OWASP Threat Modeling community page, process and data-flow diagram sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Security Engineering, Third Edition (free online chapters) `https://www.cl.cam.ac.uk/~rja14/book.html`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Draw a DFD for the Month 4 log parser, identify six threats with STRIDE and propose mitigations. **2.** Standard (~2 h): Draw a DFD for the Month 4 log parser, identify six threats with STRIDE and propose mitigations. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Draw a DFD for the Month 4 log parser, identify six threats with STRIDE and propose mitigations. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	threat-model.svg and STRIDE table; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which trust boundary was most often forgotten and why? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	DFD has labelled boundaries and each threat maps to a testable mitigation Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Threat Modeling community page, process and data-flow diagram sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE ATT&CK; write a five-line correction; retest next morning with a new 10-minute problem.

D117 · M05W1D5 · Security architecture and control categories

Phase: Academic month · **Optional date:** 2027-02-20 · **Domain resources:** C01 / C21

1. Day / sequence	Global Day 117 of 365; calendar-free M05W1D5; optional date 2027-02-20.
2. Exact topic	Security architecture and control categories
3. Exact subtopics	Preventive, detective, corrective, deterrent, compensating, directive, administrative, technical and physical controls
4. Learning objective	Select controls and explain where each sits in an attack chain
5. Primary lecture / reading + direct URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/` **Type:** Course index · **Access:** Free videos; paid notes/practice exams optional
6. Exact section / lesson locator	Professor Messer SY0-701 course index, objective 1.1 security controls video. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CIS Controls Version 8 `https://www.cisecurity.org/controls/v8`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: For one lab attack path, place nine control categories on a timeline and identify missing feedback loops. **2.** Standard (~2 h): For one lab attack path, place nine control categories on a timeline and identify missing feedback loops. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): For one lab attack path, place nine control categories on a timeline and identify missing feedback loops. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	control-timeline.pdf; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is a detective control insufficient without a response process? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Timeline is internally consistent and includes escalation/response Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Professor Messer SY0-701 course index, objective 1.1 security controls video"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Professor Messer SY0-701 Security+ official playlist; write a five-line correction; retest next morning with a new 10-minute problem.

D118 · M05W1D6 · Security policies, standards, procedures and baselines

Phase: Academic month · **Optional date:** 2027-02-21 · **Domain resources:** C22 / C06

1. Day / sequence	Global Day 118 of 365; calendar-free M05W1D6; optional date 2027-02-21.
2. Exact topic	Security policies, standards, procedures and baselines
3. Exact subtopics	Governance hierarchy, policy lifecycle, exceptions, evidence, acceptable use and change management
4. Learning objective	Distinguish a policy from a standard and a procedure
5. Primary lecture / reading + direct URL	NIST SP 800-53 Revision 5 `https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final` **Type:** Official controls catalog · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-53 control families AC, AU, CM, IR and SI; use the control catalog search. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write one mini-policy, one standard and one procedure for lab VM patching; include roles and exception handling. **2.** Standard (~2 h): Write one mini-policy, one standard and one procedure for lab VM patching; include roles and exception handling. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write one mini-policy, one standard and one procedure for lab VM patching; include roles and exception handling. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	governance-pack.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is a policy without an owner and exception path unenforceable? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Documents reference one another correctly and include measurable compliance evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-53 control families AC, AU, CM, IR and SI; use the control catalog search"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D119 · M05W1D7 · Weekly core-security review and risk practical

Phase: Academic month · **Optional date:** 2027-02-22 · **Domain resources:** C26 / C01 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 119 of 365; calendar-free M05W1D7; optional date 2027-02-22.
2. Exact topic	Weekly core-security review and risk practical
3. Exact subtopics	CIA, AAA, least privilege, threat models, risk, controls and governance; active recall
4. Learning objective	Demonstrate Month 5 Week 1 concepts through an unfamiliar scenario
5. Primary lecture / reading + direct URL	NIST SP 800-30 Revision 1 `https://csrc.nist.gov/pubs/sp/800/30/r1/final` **Type:** Official risk guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-30 risk assessment process and risk register tables. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute risk assessment for a fictional web service; identify assets, threats, controls, likelihood, impact and treatment — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute risk assessment for a fictional web service; identify assets, threats, controls, likelihood, impact and treatment — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute risk assessment for a fictional web service; identify assets, threats, controls, likelihood, impact and treatment — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M5W1-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which assumption has the greatest influence on your risk ranking? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and every high risk has a named owner and treatment Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-30 risk assessment process and risk register tables"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

Month 05 · Week 2 · daily cards

D120 · M05W2D1 · Hash functions and password storage

Phase: Academic month · **Optional date:** 2027-02-23 · **Domain resources:** F04 / C09

1. Day / sequence	Global Day 120 of 365; calendar-free M05W2D1; optional date 2027-02-23.
2. Exact topic	Hash functions and password storage
3. Exact subtopics	One-way functions, collision/preimage resistance, salts, pepper, slow KDFs, password hashing and cracking economics
4. Learning objective	Explain why a general-purpose hash is unsuitable for passwords
5. Primary lecture / reading + direct URL	CS50's Introduction to Cybersecurity `https://cs50.harvard.edu/cybersecurity/` **Type:** University course · **Access:** Free OCW; paid edX verified certificate optional
6. Exact section / lesson locator	CS50 Cybersecurity Week 1 Securing Data notes, hashing/salting/rainbow tables sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Crypto 101 `https://www.crypto101.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Hash synthetic passwords with a fast hash and a KDF in Python; compare timing and explain offline attack economics safely on your own inputs. **2.** Standard (~2 h): Hash synthetic passwords with a fast hash and a KDF in Python; compare timing and explain offline attack economics safely on your own inputs. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Hash synthetic passwords with a fast hash and a KDF in Python; compare timing and explain offline attack economics safely on your own inputs. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	password-hashing.md and timing results; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does salting not make a weak password strong? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Results are measured and the explanation distinguishes salt from work factor Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CS50 Cybersecurity Week 1 Securing Data notes, hashing/salting/rainbow tables sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup CS50's Introduction to Cybersecurity (official YouTube playlist); write a five-line correction; retest next morning with a new 10-minute problem.

D121 · M05W2D2 · Symmetric encryption, block modes and key management

Phase: Academic month · **Optional date:** 2027-02-24 · **Domain resources:** C09 / C10

1. Day / sequence	Global Day 121 of 365; calendar-free M05W2D2; optional date 2027-02-24.
2. Exact topic	Symmetric encryption, block modes and key management
3. Exact subtopics	AES concepts, block/stream ciphers, modes, IV/nonce, padding, authenticated encryption and key lifecycle
4. Learning objective	Identify misuse patterns without implementing production cryptography
5. Primary lecture / reading + direct URL	Crypto 101 `https://www.crypto101.io/` **Type:** Free course/book · **Access:** Free
6. Exact section / lesson locator	Crypto 101 block ciphers, stream ciphers and authenticated encryption sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Stanford Cryptography I `https://www.coursera.org/learn/crypto`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Use a vetted library only to encrypt/decrypt synthetic data; compare ECB and an authenticated mode visually; document never-to-use patterns. **2.** Standard (~2 h): Use a vetted library only to encrypt/decrypt synthetic data; compare ECB and an authenticated mode visually; document never-to-use patterns. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Use a vetted library only to encrypt/decrypt synthetic data; compare ECB and an authenticated mode visually; document never-to-use patterns. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	crypto-lab.py and notes; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does encryption without integrity allow tampering? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All examples use vetted libraries and the answer explains malleability Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Crypto 101 block ciphers, stream ciphers and authenticated encryption sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Stanford Cryptography I; write a five-line correction; retest next morning with a new 10-minute problem.

D122 · M05W2D3 · Public-key cryptography, key exchange and digital signatures

Phase: Academic month · **Optional date:** 2027-02-25 · **Domain resources:** C10 / C11

1. Day / sequence	Global Day 122 of 365; calendar-free M05W2D3; optional date 2027-02-25.
2. Exact topic	Public-key cryptography, key exchange and digital signatures
3. Exact subtopics	RSA/Diffie-Hellman concepts, public/private keys, signatures, certificates and non-repudiation limits
4. Learning objective	Explain which key is used for encryption versus signing
5. Primary lecture / reading + direct URL	Stanford Cryptography I https://www.coursera.org/learn/crypto **Type:** University course · **Access:** Free audit/lectures may be available; verified certificate and graded homework paid
6. Exact section / lesson locator	Stanford Cryptography I, public-key encryption and digital signatures lecture pages accessible via the Coursera audit/preview. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	A Graduate Course in Applied Cryptography https://toc.cryptobook.us/
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Generate a local key pair, sign a benign file and verify it; then corrupt one byte and observe verification failure. **2.** Standard (~2 h): Generate a local key pair, sign a benign file and verify it; then corrupt one byte and observe verification failure. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Generate a local key pair, sign a benign file and verify it; then corrupt one byte and observe verification failure. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	signature-demo.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does a valid signature prove key possession, not necessarily a person's intent? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Sign/verify workflow works and the legal/technical distinction is explicit Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Stanford Cryptography I, public-key encryption and digital signatures lecture pages accessible via the Coursera audit/preview"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Crypto 101; write a five-line correction; retest next morning with a new 10-minute problem.

D123 · M05W2D4 · TLS, certificates and chain of trust

Phase: Academic month · **Optional date:** 2027-02-26 · **Domain resources:** C12 / C13

1. Day / sequence	Global Day 123 of 365; calendar-free M05W2D4; optional date 2027-02-26.
2. Exact topic	TLS, certificates and chain of trust
3. Exact subtopics	X.509, root/intermediate/leaf certificates, CA, SAN, expiry, revocation, chain validation and hostname verification
4. Learning objective	Inspect a certificate chain and explain each validation step
5. Primary lecture / reading + direct URL	Let's Encrypt documentation `https://letsencrypt.org/docs/` **Type:** Official documentation · **Access:** Free
6. Exact section / lesson locator	Let's Encrypt documentation, certificate chain, validation and renewal pages. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	RFC 8446: TLS 1.3 `https://www.rfc-editor.org/rfc/rfc8446`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Use browser or openssl to inspect a certificate chain for an authorized site or local test certificate; draw the chain and list validation checks. **2.** Standard (~2 h): Use browser or openssl to inspect a certificate chain for an authorized site or local test certificate; draw the chain and list validation checks. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Use browser or openssl to inspect a certificate chain for an authorized site or local test certificate; draw the chain and list validation checks. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	tls-chain.svg; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What does certificate transparency add and what does it not prevent? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Chain is correctly labelled and validation is not reduced to encryption Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Let's Encrypt documentation, certificate chain, validation and renewal pages"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup RFC 8446: TLS 1.3; write a five-line correction; retest next morning with a new 10-minute problem.

D124 · M05W2D5 · Identity, federation, SSO and MFA

Phase: Academic month · **Optional date:** 2027-02-27 · **Domain resources:** C08 / A20

1. Day / sequence	Global Day 124 of 365; calendar-free M05W2D5; optional date 2027-02-27.
2. Exact topic	Identity, federation, SSO and MFA
3. Exact subtopics	OAuth 2.0, OpenID Connect, SAML concepts, IdP, SP, tokens, MFA factors, session lifetime and phishing-resistant MFA
4. Learning objective	Design an authentication flow and identify token/session failure modes
5. Primary lecture / reading + direct URL	NIST SP 800-63B `https://pages.nist.gov/800-63-4/sp800-63b.html` **Type:** Official guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-63B, authentication and authenticator management sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Microsoft SC-900 official certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-compliance-and-identity-fundamentals/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Draw an OIDC authorization-code flow with PKCE for a fictional app; annotate where tokens live and where phishing-resistant MFA applies. **2.** Standard (~2 h): Draw an OIDC authorization-code flow with PKCE for a fictional app; annotate where tokens live and where phishing-resistant MFA applies. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Draw an OIDC authorization-code flow with PKCE for a fictional app; annotate where tokens live and where phishing-resistant MFA applies. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	oidc-flow.svg; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is an access token bearer evidence rather than proof of user identity? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Flow is technically correct and token storage risks are identified Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-63B, authentication and authenticator management sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Crypto 101; write a five-line correction; retest next morning with a new 10-minute problem.

D125 · M05W2D6 · IAM lifecycle and privilege management

Phase: Academic month · **Optional date:** 2027-02-28 · **Domain resources:** C01 / C20

1. Day / sequence	Global Day 125 of 365; calendar-free M05W2D6; optional date 2027-02-28.
2. Exact topic	IAM lifecycle and privilege management
3. Exact subtopics	Provisioning, deprovisioning, joiner/mover/leaver, RBAC, ABAC, PAM, access reviews, entitlements and privilege creep
4. Learning objective	Design an access review that detects privilege creep
5. Primary lecture / reading + direct URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/` **Type:** Course index · **Access:** Free videos; paid notes/practice exams optional
6. Exact section / lesson locator	Professor Messer SY0-701 course index, IAM objectives 1.5 and 4.6. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST NICE Workforce Framework `https://www.nist.gov/itl/applied-cybersecurity/nice`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a synthetic employee lifecycle with three role changes, simulate accumulated entitlements and write an access-review decision log. **2.** Standard (~2 h): Create a synthetic employee lifecycle with three role changes, simulate accumulated entitlements and write an access-review decision log. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a synthetic employee lifecycle with three role changes, simulate accumulated entitlements and write an access-review decision log. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	iam-review.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can RBAC fail when users accumulate exceptions? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Scenario is complete and review removes excess rights with documented approval Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Professor Messer SY0-701 course index, IAM objectives 1.5 and 4.6"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Professor Messer SY0-701 Security+ official playlist; write a five-line correction; retest next morning with a new 10-minute problem.

D126 · M05W2D7 · Weekly cryptography and identity review

Phase: Academic month · **Optional date:** 2027-03-01 · **Domain resources:** C09 / C08 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 126 of 365; calendar-free M05W2D7; optional date 2027-03-01.
2. Exact topic	Weekly cryptography and identity review
3. Exact subtopics	Hash/KDF, symmetric crypto, AEAD, public-key crypto, TLS, federation, MFA and IAM; active recall
4. Learning objective	Demonstrate correct use of cryptographic primitives and identity terminology
5. Primary lecture / reading + direct URL	Crypto 101 https://www.crypto101.io/ **Type:** Free course/book · **Access:** Free
6. Exact section / lesson locator	Crypto 101 review sections and C10 selected lectures. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-63B https://pages.nist.gov/800-63-4/sp800-63b.html
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete 20 closed-book questions, one certificate-chain analysis and one IAM design exercise; correct all mistakes with new examples — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete 20 closed-book questions, one certificate-chain analysis and one IAM design exercise; correct all mistakes with new examples — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete 20 closed-book questions, one certificate-chain analysis and one IAM design exercise; correct all mistakes with new examples — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M5W2-review.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which cryptographic primitive would you use for each of confidentiality, integrity and authentication? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 75 percent and no primitive is confused with another Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Crypto 101 review sections and C10 selected lectures"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Stanford Cryptography I; write a five-line correction; retest next morning with a new 10-minute problem.

Month 05 · Week 3 · daily cards

D127 · M05W3D1 · Endpoint, network, application and data security controls

Phase: Academic month · **Optional date:** 2027-03-02 · **Domain resources:** C01 / C21

1. Day / sequence	Global Day 127 of 365; calendar-free M05W3D1; optional date 2027-03-02.
2. Exact topic	Endpoint, network, application and data security controls
3. Exact subtopics	EDR, hardening, segmentation, WAF, secure coding, DLP, encryption and backups
4. Learning objective	Map controls to attack paths and identify residual risk
5. Primary lecture / reading + direct URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/` **Type:** Course index · **Access:** Free videos; paid notes/practice exams optional
6. Exact section / lesson locator	Professor Messer SY0-701 objectives 2, 3 and 4; use exact video titles in the course index. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CIS Controls Version 8 `https://www.cisecurity.org/controls/v8`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Build a control map for a fictional three-tier app, with five attack paths and a detective control for each. **2.** Standard (~2 h): Build a control map for a fictional three-tier app, with five attack paths and a detective control for each. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Build a control map for a fictional three-tier app, with five attack paths and a detective control for each. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	controls-map.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which two controls share a single failure domain? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Map includes prevention, detection, response and shared-failure analysis Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Professor Messer SY0-701 objectives 2, 3 and 4; use exact video titles in the course index"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Professor Messer SY0-701 Security+ official playlist; write a five-line correction; retest next morning with a new 10-minute problem.

D128 · M05W3D2 · Patch and vulnerability management lifecycle

Phase: Academic month · **Optional date:** 2027-03-03 · **Domain resources:** C18 / E08

1. Day / sequence	Global Day 128 of 365; calendar-free M05W3D2; optional date 2027-03-03.
2. Exact topic	Patch and vulnerability management lifecycle
3. Exact subtopics	Asset inventory, discovery, prioritization, testing, deployment, verification, exception and metrics
4. Learning objective	Build a repeatable patch workflow with evidence and rollback
5. Primary lecture / reading + direct URL	MITRE ATT&CK `https://attack.mitre.org/` **Type:** Knowledge base · **Access:** Free
6. Exact section / lesson locator	CISA KEV catalog and MITRE ATT&CK pages for one relevant technique. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NVD `https://nvd.nist.gov/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Select five synthetic vulnerabilities with CVSS/KEV-like metadata, prioritize them by business context, and define test/rollback for each. **2.** Standard (~2 h): Select five synthetic vulnerabilities with CVSS/KEV-like metadata, prioritize them by business context, and define test/rollback for each. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Select five synthetic vulnerabilities with CVSS/KEV-like metadata, prioritize them by business context, and define test/rollback for each. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	vuln-prioritization.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can a lower CVSS score be patched first in a real environment? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Priorities are justified with context and each item has verification evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CISA KEV catalog and MITRE ATT&CK pages for one relevant technique"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE D3FEND; write a five-line correction; retest next morning with a new 10-minute problem.

D129 · M05W3D3 · Phishing defense and security awareness

Phase: Academic month · **Optional date:** 2027-03-04 · **Domain resources:** C01 / B17

1. Day / sequence	Global Day 129 of 365; calendar-free M05W3D3; optional date 2027-03-04.
2. Exact topic	Phishing defense and security awareness
3. Exact subtopics	Social engineering, phishing indicators, URL parsing, attachments, reporting culture and measurable awareness
4. Learning objective	Analyze a synthetic phishing email without clicking or downloading
5. Primary lecture / reading + direct URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/` **Type:** Course index · **Access:** Free videos; paid notes/practice exams optional
6. Exact section / lesson locator	Professor Messer SY0-701 objective 5.6 user training and phishing videos. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CISA cybersecurity advisories `https://www.cisa.gov/news-events/cybersecurity-advisories`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create or use a synthetic email sample, identify five indicators, write a user-facing report and one technical control. **2.** Standard (~2 h): Create or use a synthetic email sample, identify five indicators, write a user-facing report and one technical control. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create or use a synthetic email sample, identify five indicators, write a user-facing report and one technical control. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	phishing-analysis.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is blaming users a weak control compared with report-driven engineering? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Analysis is safe, indicators are specific, and both human and technical controls are present Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Professor Messer SY0-701 objective 5.6 user training and phishing videos"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Professor Messer SY0-701 Security+ official playlist; write a five-line correction; retest next morning with a new 10-minute problem.

D130 · M05W3D4 · Incident response lifecycle and tabletop exercise

Phase: Academic month · **Optional date:** 2027-03-05 · **Domain resources:** C07 / C06

1. Day / sequence	Global Day 130 of 365; calendar-free M05W3D4; optional date 2027-03-05.
2. Exact topic	Incident response lifecycle and tabletop exercise
3. Exact subtopics	Preparation, detection, analysis, containment, eradication, recovery, lessons learned, roles and communications
4. Learning objective	Run a tabletop incident using only synthetic data
5. Primary lecture / reading + direct URL	NIST SP 800-61 Revision 3 `https://csrc.nist.gov/pubs/sp/800/61/r3/final` **Type:** Official guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-61r3 incident response life cycle and CSF function alignment. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Conduct a 60-minute tabletop for a synthetic credential-theft incident; record decisions, evidence needs, escalation and communication. **2.** Standard (~2 h): Conduct a 60-minute tabletop for a synthetic credential-theft incident; record decisions, evidence needs, escalation and communication. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Conduct a 60-minute tabletop for a synthetic credential-theft incident; record decisions, evidence needs, escalation and communication. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	tabletop-report.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which decision required information you did not have and what detection would provide it? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Report includes timeline, decisions, evidence gaps and lessons learned Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-61r3 incident response life cycle and CSF function alignment"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D131 · M05W3D5 · Business continuity, disaster recovery and backup validation

Phase: Academic month · **Optional date:** 2027-03-06 · **Domain resources:** C27 / F12

1. Day / sequence	Global Day 131 of 365; calendar-free M05W3D5; optional date 2027-03-06.
2. Exact topic	Business continuity, disaster recovery and backup validation
3. Exact subtopics	BIA, RTO, RPO, backup types, restore testing, failover, dependencies and crisis communication
4. Learning objective	Prove that a backup can be restored and quantify the test result
5. Primary lecture / reading + direct URL	NIST SP 800-34 Revision 1 https://csrc.nist.gov/pubs/sp/800/34/r1/final **Type:** Official continuity guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-34r1, BIA and contingency-planning sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Oracle VirtualBox User Manual https://www.virtualbox.org/manual/
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Restore the Month 1 VM snapshot or file backup, measure elapsed time, compare hashes and state observed RTO/RPO. **2.** Standard (~2 h): Restore the Month 1 VM snapshot or file backup, measure elapsed time, compare hashes and state observed RTO/RPO. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Restore the Month 1 VM snapshot or file backup, measure elapsed time, compare hashes and state observed RTO/RPO. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	dr-test.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does an untested backup fail the business objective even if the job reports success? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Restore is proven by hashes and test has measured RTO/RPO Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-34r1, BIA and contingency-planning sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D132 · M05W3D6 · GRC frameworks and legal-obligation distinctions

Phase: Academic month · **Optional date:** 2027-03-07 · **Domain resources:** C06 / C23

1. Day / sequence	Global Day 132 of 365; calendar-free M05W3D6; optional date 2027-03-07.
2. Exact topic	GRC frameworks and legal-obligation distinctions
3. Exact subtopics	Regulations, laws, contracts, standards, frameworks, best practices, controls, audits and compliance evidence
4. Learning objective	Correctly classify common cybersecurity documents and obligations
5. Primary lecture / reading + direct URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework` **Type:** Framework · **Access:** Free
6. Exact section / lesson locator	NIST CSF 2.0, Govern function and implementation examples. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	ISO/IEC 27001 overview `https://www.iso.org/standard/27001`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Build a comparison table for GDPR, ISO/IEC 27001, NIST CSF, CIS Controls and PCI DSS-like contract obligations; label each as law, regulation, standard, framework or best practice. **2.** Standard (~2 h): Build a comparison table for GDPR, ISO/IEC 27001, NIST CSF, CIS Controls and PCI DSS-like contract obligations; label each as law, regulation, standard, framework or best practice. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Build a comparison table for GDPR, ISO/IEC 27001, NIST CSF, CIS Controls and PCI DSS-like contract obligations; label each as law, regulation, standard, framework or best practice. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	grc-classification.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does following a framework not automatically make an organization legally compliant? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All classifications are correct in a defined jurisdiction context Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST CSF 2.0, Govern function and implementation examples"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup CIS Controls Version 8; write a five-line correction; retest next morning with a new 10-minute problem.

D133 · M05W3D7 · Weekly controls, GRC and incident response review

Phase: Academic month · **Optional date:** 2027-03-08 · **Domain resources:** C07 / C26 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 133 of 365; calendar-free M05W3D7; optional date 2027-03-08.
2. Exact topic	Weekly controls, GRC and incident response review
3. Exact subtopics	Endpoint/network/app/data controls, vuln management, awareness, IR, BCDR and frameworks; retrieval
4. Learning objective	Demonstrate Month 5 Week 3 competence through a scenario-based assessment
5. Primary lecture / reading + direct URL	NIST SP 800-61 Revision 3 `https://csrc.nist.gov/pubs/sp/800/61/r3/final` **Type:** Official guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-61r3 and C06 CSF 2.0 crosswalk. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-30 Revision 1 `https://csrc.nist.gov/pubs/sp/800/30/r1/final`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete an integrated scenario: triage an incident, classify a vulnerability, choose controls and identify legal/framework implications — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete an integrated scenario: triage an incident, classify a vulnerability, choose controls and identify legal/framework implications — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete an integrated scenario: triage an incident, classify a vulnerability, choose controls and identify legal/framework implications — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M5W3-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which evidence would support both an incident report and an audit? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and all classifications have evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-61r3 and C06 CSF 2.0 crosswalk"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

Month 05 · Week 4 · daily cards

D134 · M05W4D1 · Privacy by design and data classification

Phase: Academic month · **Optional date:** 2027-03-09 · **Domain resources:** C24 / C25

1. Day / sequence	Global Day 134 of 365; calendar-free M05W4D1; optional date 2027-03-09.
2. Exact topic	Privacy by design and data classification
3. Exact subtopics	Personal data, special categories, purpose limitation, minimization, retention, anonymization, pseudonymization and data flow
4. Learning objective	Add privacy controls to a software design and risk register
5. Primary lecture / reading + direct URL	GDPR full text (EUR-Lex) `https://eur-lex.europa.eu/eli/reg/2016/679/oj` **Type:** Regulation/legal text · **Access:** Free
6. Exact section / lesson locator	GDPR Articles 5, 25, 32, 33 and 35; NIST Privacy Framework via C25 for supporting structure. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Privacy Framework `https://www.nist.gov/privacy-framework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Classify ten synthetic data fields, draw a data flow, define retention and propose three privacy controls. **2.** Standard (~2 h): Classify ten synthetic data fields, draw a data flow, define retention and propose three privacy controls. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Classify ten synthetic data fields, draw a data flow, define retention and propose three privacy controls. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	privacy-design.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which data field is most sensitive and what technical control reduces exposure while preserving function? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Classifications are justified and data flow includes retention and deletion points Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "GDPR Articles 5, 25, 32, 33 and 35; NIST Privacy Framework via C25 for supporting structure"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Privacy Framework; write a five-line correction; retest next morning with a new 10-minute problem.

D135 · M05W4D2 · Security architecture review of the capstone

Phase: Academic month · **Optional date:** 2027-03-10 · **Domain resources:** C15 / C17

1. Day / sequence	Global Day 135 of 365; calendar-free M05W4D2; optional date 2027-03-10.
2. Exact topic	Security architecture review of the capstone
3. Exact subtopics	Trust boundaries, identity, crypto, logging, input validation, failure modes and control dependencies
4. Learning objective	Review the Month 4 automation tool as a security architect
5. Primary lecture / reading + direct URL	OWASP Application Security Verification Standard `https://owasp.org/www-project-application-security-verification-standard/` **Type:** Standard/reference · **Access:** Free
6. Exact section / lesson locator	OWASP ASVS selected Level 1 requirements for authentication, logging, data protection and validation. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Threat Modeling community page `https://owasp.org/www-community/Threat_Modeling`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Perform a design review of the log parser, create a findings register and fix the highest architectural risk. **2.** Standard (~2 h): Perform a design review of the log parser, create a findings register and fix the highest architectural risk. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Perform a design review of the log parser, create a findings register and fix the highest architectural risk. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	architecture-review.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which control failure would invalidate multiple other controls? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Findings are prioritized by impact and at least one design fix is implemented Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP ASVS selected Level 1 requirements for authentication, logging, data protection and validation"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Secure Coding Practices Quick Reference Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D136 · M05W4D3 · Certification readiness without exam obsession

Phase: Academic month · **Optional date:** 2027-03-11 · **Domain resources:** C03 / C01

1. Day / sequence	Global Day 136 of 365; calendar-free M05W4D3; optional date 2027-03-11.
2. Exact topic	Certification readiness without exam obsession
3. Exact subtopics	ISC2 CC and Security+ objective mapping, practice-exam strategy, evidence of competence and cost-benefit analysis
4. Learning objective	Decide rationally whether to pursue an entry-level certification at Month 12
5. Primary lecture / reading + direct URL	ISC2 Certified in Cybersecurity Exam Outline `https://www.isc2.org/certifications/cc/cc-certification-exam-outline` **Type:** Official exam outline · **Access:** Free
6. Exact section / lesson locator	ISC2 CC Exam Outline effective 2026-09-01; A18 CompTIA Security+ V7/V8 official pages. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Map your portfolio evidence to five CC domains and five Security+ domains; take only free official practice questions and write a decision memo. **2.** Standard (~2 h): Map your portfolio evidence to five CC domains and five Security+ domains; take only free official practice questions and write a decision memo. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Map your portfolio evidence to five CC domains and five Security+ domains; take only free official practice questions and write a decision memo. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	certification-decision.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What does the certification prove that your projects do not, and vice versa? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Memo is evidence-based, budget-aware and does not promise employment Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "ISC2 CC Exam Outline effective 2026-09-01; A18 CompTIA Security+ V7/V8 official pages"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup ISC2 CC self-study resources; write a five-line correction; retest next morning with a new 10-minute problem.

D137 · M05W4D4 · Month 5 capstone: security control baseline

Phase: Academic month · **Optional date:** 2027-03-12 · **Domain resources:** C06 / C21

1. Day / sequence	Global Day 137 of 365; calendar-free M05W4D4; optional date 2027-03-12.
2. Exact topic	Month 5 capstone: security control baseline
3. Exact subtopics	Risk register, control selection, implementation, testing, exceptions and residual risk
4. Learning objective	Produce a complete security baseline for the student's own lab
5. Primary lecture / reading + direct URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework` **Type:** Framework · **Access:** Free
6. Exact section / lesson locator	NIST CSF 2.0 quick-start guides and implementation examples. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CIS Controls Version 8 `https://www.cisecurity.org/controls/v8`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Select ten controls from your lab, test each with evidence, document exceptions and produce a 90-day improvement plan. **2.** Standard (~2 h): Select ten controls from your lab, test each with evidence, document exceptions and produce a 90-day improvement plan. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Select ten controls from your lab, test each with evidence, document exceptions and produce a 90-day improvement plan. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-02 security-baseline repository; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which control failed its test and what was the root cause? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All ten controls have objective tests and residual risk is stated Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST CSF 2.0 quick-start guides and implementation examples"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup CIS Controls Version 8; write a five-line correction; retest next morning with a new 10-minute problem.

D138 · M05W4D5 · Month 5 practical examination and milestone gate

Phase: Academic month · **Optional date:** 2027-03-13 · **Domain resources:** C03 / C06

1. Day / sequence	Global Day 138 of 365; calendar-free M05W4D5; optional date 2027-03-13.
2. Exact topic	Month 5 practical examination and milestone gate
3. Exact subtopics	Security principles, crypto, identity, controls, risk, IR, privacy and GRC; practical scenario
4. Learning objective	Demonstrate core security competence with independent reasoning under time pressure
5. Primary lecture / reading + direct URL	ISC2 Certified in Cybersecurity Exam Outline `https://www.isc2.org/certifications/cc/cc-certification-exam-outline` **Type:** Official exam outline · **Access:** Free
6. Exact section / lesson locator	ISC2 CC Exam Outline, five domains; use it only as a revision checklist. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete a 120-minute practical: analyze an incident, select crypto primitives, design IAM, prioritize vulnerabilities, and write a risk register. **2.** Standard (~2 h): Complete a 120-minute practical: analyze an incident, select crypto primitives, design IAM, prioritize vulnerabilities, and write a risk register. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete a 120-minute practical: analyze an incident, select crypto primitives, design IAM, prioritize vulnerabilities, and write a risk register. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M5-assessment.pdf and scorecard; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: How would you justify a control decision to a non-technical manager using evidence? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100, milestone gate passed, practical at least 18/25 and safety at least 9/10 Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "ISC2 CC Exam Outline, five domains; use it only as a revision checklist"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup ISC2 CC self-study resources; write a five-line correction; retest next morning with a new 10-minute problem.

D139 · M05W4D6 · Monthly review, gap repair and Month 6 preview

Phase: Academic month · **Optional date:** 2027-03-14 · **Domain resources:** C01 / F04

1. Day / sequence	Global Day 139 of 365; calendar-free M05W4D6; optional date 2027-03-14.
2. Exact topic	Monthly review, gap repair and Month 6 preview
3. Exact subtopics	Error-log analysis, crypto misconceptions, risk ranking errors, framework classifications and project feedback
4. Learning objective	Repair Month 5 gaps and prepare web/API prerequisites
5. Primary lecture / reading + direct URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/` **Type:** Course index · **Access:** Free videos; paid notes/practice exams optional
6. Exact section / lesson locator	Professor Messer SY0-701 course index; choose three weakest objectives. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CS50's Introduction to Cybersecurity `https://cs50.harvard.edu/cybersecurity/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Rework every failed assessment item, write ten flashcards, update the security baseline, and review HTTP/cookies from Month 1 and Month 2. **2.** Standard (~2 h): Rework every failed assessment item, write ten flashcards, update the security baseline, and review HTTP/cookies from Month 1 and Month 2. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Rework every failed assessment item, write ten flashcards, update the security baseline, and review HTTP/cookies from Month 1 and Month 2. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M5-review.md and retest score; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which core security concept is still fuzzy enough to weaken web-security decisions? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Retest score at least 80 percent and each original gap has a new worked example Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Professor Messer SY0-701 course index; choose three weakest objectives"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Professor Messer SY0-701 Security+ official playlist; write a five-line correction; retest next morning with a new 10-minute problem.

D140 · M05W4D7 · Spaced revision, recovery and readiness check

Phase: Academic month · **Optional date:** 2027-03-15 · **Domain resources:** F04 / C09 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 140 of 365; calendar-free M05W4D7; optional date 2027-03-15.
2. Exact topic	Spaced revision, recovery and readiness check
3. Exact subtopics	CIA/AAA, risk, crypto, TLS, IAM, IR and GRC; active recall and light lab maintenance
4. Learning objective	Preserve core security knowledge and prepare a safe web lab
5. Primary lecture / reading + direct URL	CS50's Introduction to Cybersecurity `https://cs50.harvard.edu/cybersecurity/` **Type:** University course · **Access:** Free OCW; paid edX verified certificate optional
6. Exact section / lesson locator	CS50 Cybersecurity Weeks 0-4 review notes. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Crypto 101 `https://www.crypto101.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, review all flashcards, verify VM snapshots, install Docker or confirm PortSwigger access, and rest — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, review all flashcards, verify VM snapshots, install Docker or confirm PortSwigger access, and rest — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, review all flashcards, verify VM snapshots, install Docker or confirm PortSwigger access, and rest — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M5-consolidation.md and lab-readiness.txt; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Explain the difference between authentication, authorization, accountability and non-repudiation in one minute Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All prerequisite tools are available and the explanation is correct Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CS50 Cybersecurity Weeks 0-4 review notes"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup CS50's Introduction to Cybersecurity (official YouTube playlist); write a five-line correction; retest next morning with a new 10-minute problem.

Month 06 — Web security, API security and secure coding

Days D141-D168. Each day has the same 13-field structure. Use the Core, Standard or Intensive track; the learning objective does not change. Day 7 of each week is lighter by design.

Week	Daily topics
Week 1	D1: Web architecture and HTTP request lifecycle D2: HTTP methods, headers, cookies and security headers D3: Sessions, cookies and authentication flaws D4: Access control and IDOR/BOLA D5: OWASP Top 10 as a coverage index D6: Secure coding: input validation and output encoding D7: Weekly web foundations review and local lab setup
Week 2	D1: SQL injection and parameterized queries D2: Cross-site scripting and DOM security D3: CSRF, SameSite and anti-CSRF tokens D4: SSRF and outbound request controls D5: Path traversal and file upload security D6: Weekly injection and client-side security review D7: API fundamentals and authorization models
Week 3	D1: Rate limiting, input validation and abuse cases D2: Secrets management and configuration security D3: Secure SDLC and code review gates D4: Dependency and supply-chain security D5: Weekly API, SDLC and supply-chain review D6: Secure web application engineering sprint: design D7: Secure web application engineering sprint: implementation
Week 4	D1: Secure web application engineering sprint: testing D2: Local web security assessment of the app D3: Dependency and CI security for the capstone D4: Portfolio publication of secure app and assessment D5: Month 6 practical examination and milestone gate D6: Monthly review and gap repairs D7: Spaced revision, recovery and Month 7 preview

> **Gate:** score the Month 6 assessment using the 100-point rubric in Volume 6. If score <70 or safety <9/10, follow the six-step repair protocol before advancing.

Month 06 · Week 1 · daily cards

D141 · M06W1D1 · Web architecture and HTTP request lifecycle

Phase: Academic month · **Optional date:** 2027-03-16 · **Domain resources:** W01 / W04

1. Day / sequence	Global Day 141 of 365; calendar-free M06W1D1; optional date 2027-03-16.
2. Exact topic	Web architecture and HTTP request lifecycle
3. Exact subtopics	DNS, TCP, TLS, HTTP request, routing, application, database, response, browser rendering and same-origin policy
4. Learning objective	Trace one request across the full web stack and identify trust boundaries
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, Getting Started and Essential Skills topics. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MDN HTTP documentation `https://developer.mozilla.org/en-US/docs/Web/HTTP`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Draw an end-to-end request lifecycle diagram for a local app and capture one request/response with browser DevTools or Burp. **2.** Standard (~2 h): Draw an end-to-end request lifecycle diagram for a local app and capture one request/response with browser DevTools or Burp. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Draw an end-to-end request lifecycle diagram for a local app and capture one request/response with browser DevTools or Burp. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	web-request-lifecycle.svg and annotated HTTP exchange; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Where can input be transformed or validated and why is client-side validation insufficient? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Diagram includes at least seven stages and all client-side checks are marked untrusted Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, Getting Started and Essential Skills topics"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D142 · M06W1D2 · HTTP methods, headers, cookies and security headers

Phase: Academic month · **Optional date:** 2027-03-17 · **Domain resources:** W04 / W17

1. Day / sequence	Global Day 142 of 365; calendar-free M06W1D2; optional date 2027-03-17.
2. Exact topic	HTTP methods, headers, cookies and security headers
3. Exact subtopics	GET/POST/PUT/PATCH/DELETE, idempotency, status codes, Set-Cookie, Secure, HttpOnly, SameSite, CSP, HSTS and CORS basics
4. Learning objective	Interpret security-relevant headers and explain their limitations
5. Primary lecture / reading + direct URL	MDN HTTP documentation `https://developer.mozilla.org/en-US/docs/Web/HTTP` **Type:** Official documentation · **Access:** Free
6. Exact section / lesson locator	MDN HTTP documentation, Methods, Headers, Cookies, CSP and CORS sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Inspect headers from a local app and an authorized site; propose a header policy and predict one functional breakage. **2.** Standard (~2 h): Inspect headers from a local app and an authorized site; propose a header policy and predict one functional breakage. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Inspect headers from a local app and an authorized site; propose a header policy and predict one functional breakage. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	headers-policy.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does SameSite=Lax not solve every CSRF problem? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All assigned headers are classified and limitations are explicit Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "MDN HTTP documentation, Methods, Headers, Cookies, CSP and CORS sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MDN HTTP Overview; write a five-line correction; retest next morning with a new 10-minute problem.

D143 · M06W1D3 · Sessions, cookies and authentication flaws

Phase: Academic month · **Optional date:** 2027-03-18 · **Domain resources:** W01 / C08

1. Day / sequence	Global Day 143 of 365; calendar-free M06W1D3; optional date 2027-03-18.
2. Exact topic	Sessions, cookies and authentication flaws
3. Exact subtopics	Session identifiers, fixation, entropy, timeout, logout, rotation, password reset and multi-factor flows
4. Learning objective	Design a secure session lifecycle and identify weak token handling
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, Authentication topic and Apprentice labs. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-63B `https://pages.nist.gov/800-63-4/sp800-63b.html`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Solve one authentication Apprentice lab without a walkthrough, then write secure session requirements and a remediation test. **2.** Standard (~2 h): Solve one authentication Apprentice lab without a walkthrough, then write secure session requirements and a remediation test. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Solve one authentication Apprentice lab without a walkthrough, then write secure session requirements and a remediation test. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	auth-lab-notes.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why must session identifiers rotate after privilege change? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Lab is solved in the authorized academy and remediation includes server-side invalidation Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, Authentication topic and Apprentice labs"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D144 · M06W1D4 · Access control and IDOR/BOLA

Phase: Academic month · **Optional date:** 2027-03-19 · **Domain resources:** W01 / C16

1. Day / sequence	Global Day 144 of 365; calendar-free M06W1D4; optional date 2027-03-19.
2. Exact topic	Access control and IDOR/BOLA
3. Exact subtopics	Vertical/horizontal privilege escalation, object references, authorization on every request, deny by default and multi-step checks
4. Learning objective	Prove where authorization must occur in a request flow
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, Access Control topic; C16 OWASP API Top 10 API1 BOLA. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP API Security Top 10 `https://owasp.org/API-Security/editions/2023/en/0x11-t10/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Solve one IDOR/access-control Apprentice lab; implement a small local function that authorizes by user and object owner. **2.** Standard (~2 h): Solve one IDOR/access-control Apprentice lab; implement a small local function that authorizes by user and object owner. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Solve one IDOR/access-control Apprentice lab; implement a small local function that authorizes by user and object owner. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	access-control.md and code snippet; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is hiding an object ID in the UI not an authorization control? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Lab is solved and local code denies access server-side Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, Access Control topic; C16 OWASP API Top 10 API1 BOLA"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D145 · M06W1D5 · OWASP Top 10 as a coverage index

Phase: Academic month · **Optional date:** 2027-03-20 · **Domain resources:** C14 / W01

1. Day / sequence	Global Day 145 of 365; calendar-free M06W1D5; optional date 2027-03-20.
2. Exact topic	OWASP Top 10 as a coverage index
3. Exact subtopics	A01-A10 categories, root causes, prevention patterns and limitations of a risk taxonomy
4. Learning objective	Map each category to a lab, a prevention control and an evidence source
5. Primary lecture / reading + direct URL	OWASP Top 10 `https://owasp.org/www-project-top-ten/` **Type:** Reference · **Access:** Free
6. Exact section / lesson locator	OWASP Top 10 project, A01 through A10 pages. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	PortSwigger Web Security Academy `https://portswigger.net/web-security`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Build a personal coverage matrix with ten categories and a PortSwigger lab or local exercise for each; label which are not yet completed. **2.** Standard (~2 h): Build a personal coverage matrix with ten categories and a PortSwigger lab or local exercise for each; label which are not yet completed. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Build a personal coverage matrix with ten categories and a PortSwigger lab or local exercise for each; label which are not yet completed. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	owasp-matrix.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does completing an OWASP lab not prove an entire application is secure? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Matrix is complete and explicitly states no claim of full coverage Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Top 10 project, A01 through A10 pages"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D146 · M06W1D6 · Secure coding: input validation and output encoding

Phase: Academic month · **Optional date:** 2027-03-21 · **Domain resources:** W17 / P08

1. Day / sequence	Global Day 146 of 365; calendar-free M06W1D6; optional date 2027-03-21.
2. Exact topic	Secure coding: input validation and output encoding
3. Exact subtopics	Allow-lists, canonicalization, type/length/range checks, context-aware encoding, template escaping and Unicode pitfalls
4. Learning objective	Fix a deliberately vulnerable local code snippet using safe library functions
5. Primary lecture / reading + direct URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/` **Type:** Official checklist library · **Access:** Free
6. Exact section / lesson locator	OWASP Cheat Sheet Series, Input Validation and XSS Prevention cheat sheets. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Secure Coding Practices Quick Reference Guide `https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Implement server-side validation and context-aware output encoding in three synthetic snippets; add tests for Unicode, null bytes and long strings. **2.** Standard (~2 h): Implement server-side validation and context-aware output encoding in three synthetic snippets; add tests for Unicode, null bytes and long strings. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Implement server-side validation and context-aware output encoding in three synthetic snippets; add tests for Unicode, null bytes and long strings. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	secure-validation.py and tests; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can validation fail if canonicalization happens after the security check? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Tests pass and all outputs are escaped in the correct context Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Cheat Sheet Series, Input Validation and XSS Prevention cheat sheets"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Application Security Verification Standard; write a five-line correction; retest next morning with a new 10-minute problem.

D147 · M06W1D7 · Weekly web foundations review and local lab setup

Phase: Academic month · **Optional date:** 2027-03-22 · **Domain resources:** W11 / W08 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 147 of 365; calendar-free M06W1D7; optional date 2027-03-22.
2. Exact topic	Weekly web foundations review and local lab setup
3. Exact subtopics	HTTP, headers, sessions, access control, OWASP Top 10, validation and output encoding; active recall
4. Learning objective	Demonstrate Month 6 Week 1 understanding with a small local app
5. Primary lecture / reading + direct URL	OWASP WebGoat `https://owasp.org/www-project-webgoat/` **Type:** Vulnerable-by-design lessons · **Access:** Free/open-source
6. Exact section / lesson locator	OWASP WebGoat HTTP basics and access-control lessons; use only in an isolated local container/VM. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Juice Shop `https://owasp.org/www-project-juice-shop/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Deploy a local vulnerable app on loopback only, complete three WebGoat or PortSwigger labs, and document the defensive fix for each — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Deploy a local vulnerable app on loopback only, complete three WebGoat or PortSwigger labs, and document the defensive fix for each — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Deploy a local vulnerable app on loopback only, complete three WebGoat or PortSwigger labs, and document the defensive fix for each — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M6W1-review.md and lab evidence; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which vulnerability was caused by missing server-side authorization rather than bad input? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and all services are bound to localhost/internal network Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP WebGoat HTTP basics and access-control lessons; use only in an isolated local container/VM"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

Month 06 · Week 2 · daily cards

D148 · M06W2D1 · SQL injection and parameterized queries

Phase: Academic month · **Optional date:** 2027-03-23 · **Domain resources:** W01 / P08

1. Day / sequence	Global Day 148 of 365; calendar-free M06W2D1; optional date 2027-03-23.
2. Exact topic	SQL injection and parameterized queries
3. Exact subtopics	In-band, blind and second-order injection; UNION concepts; stacked queries; stored procedures; ORMs; parameterization; least privilege
4. Learning objective	Demonstrate a PortSwigger SQLi lab and repair an equivalent local vulnerable query
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, SQL Injection topic and SQL injection learning path. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Secure Coding Practices Quick Reference Guide `https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete two Apprentice SQLi labs in the Academy, then rewrite a local synthetic vulnerable query with bound parameters and tests. **2.** Standard (~2 h): Complete two Apprentice SQLi labs in the Academy, then rewrite a local synthetic vulnerable query with bound parameters and tests. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete two Apprentice SQLi labs in the Academy, then rewrite a local synthetic vulnerable query with bound parameters and tests. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	sqli-remediation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does parameterization prevent data from changing SQL structure? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Labs are solved only in authorized environments and local tests include malicious strings Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, SQL Injection topic and SQL injection learning path"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D149 · M06W2D2 · Cross-site scripting and DOM security

Phase: Academic month · **Optional date:** 2027-03-24 · **Domain resources:** W01 / W17

1. Day / sequence	Global Day 149 of 365; calendar-free M06W2D2; optional date 2027-03-24.
2. Exact topic	Cross-site scripting and DOM security
3. Exact subtopics	Reflected, stored and DOM XSS; contexts; CSP; Trusted Types concepts; sanitization; framework auto-escaping and dangerous sinks
4. Learning objective	Identify sinks and apply context-specific defenses
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, Cross-site scripting topic and Apprentice labs. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete two XSS Apprentice labs, inspect the DOM sink, and write a local safe-rendering example plus CSP policy. **2.** Standard (~2 h): Complete two XSS Apprentice labs, inspect the DOM sink, and write a local safe-rendering example plus CSP policy. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete two XSS Apprentice labs, inspect the DOM sink, and write a local safe-rendering example plus CSP policy. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	xss-notes.md and CSP example; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can HTML entity encoding fail inside a JavaScript string or URL context? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Each lab has a root cause and each local output uses the correct encoding Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, Cross-site scripting topic and Apprentice labs"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D150 · M06W2D3 · CSRF, SameSite and anti-CSRF tokens

Phase: Academic month · **Optional date:** 2027-03-25 · **Domain resources:** W01 / W17

1. Day / sequence	Global Day 150 of 365; calendar-free M06W2D3; optional date 2027-03-25.
2. Exact topic	CSRF, SameSite and anti-CSRF tokens
3. Exact subtopics	State-changing requests, cookie ambient authority, synchronizer tokens, double-submit, Origin/ Referer checks and same-site policy
4. Learning objective	Explain which requests require CSRF defense and how tokens should be validated
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, CSRF topic and Apprentice labs. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Solve one CSRF lab, implement a signed anti-CSRF token in a local app, and test token reuse and mismatch cases. **2.** Standard (~2 h): Solve one CSRF lab, implement a signed anti-CSRF token in a local app, and test token reuse and mismatch cases. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Solve one CSRF lab, implement a signed anti-CSRF token in a local app, and test token reuse and mismatch cases. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	csrf-defense.py and lab notes; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does a CSRF token need to be tied to a user session? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Lab is solved and local token validation rejects all assigned negative tests Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, CSRF topic and Apprentice labs"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D151 · M06W2D4 · SSRF and outbound request controls

Phase: Academic month · **Optional date:** 2027-03-26 · **Domain resources:** W01 / C17

1. Day / sequence	Global Day 151 of 365; calendar-free M06W2D4; optional date 2027-03-26.
2. Exact topic	SSRF and outbound request controls
3. Exact subtopics	Internal service access, URL parsing, DNS rebinding concepts, metadata services, allow-lists, network egress and response handling
4. Learning objective	Design server-side controls for a feature that fetches a URL
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, SSRF topic and Apprentice labs. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Threat Modeling community page `https://owasp.org/www-community/Threat_Modeling`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Solve one basic SSRF lab, then write a local fetcher that enforces scheme, host allow-list, DNS resolution checks and egress restrictions. **2.** Standard (~2 h): Solve one basic SSRF lab, then write a local fetcher that enforces scheme, host allow-list, DNS resolution checks and egress restrictions. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Solve one basic SSRF lab, then write a local fetcher that enforces scheme, host allow-list, DNS resolution checks and egress restrictions. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	ssrf-lab.md and fetcher.py; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is a string blocklist of localhost insufficient against SSRF? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Authorized lab is solved and local implementation includes multiple independent checks Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, SSRF topic and Apprentice labs"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D152 · M06W2D5 · Path traversal and file upload security

Phase: Academic month · **Optional date:** 2027-03-27 · **Domain resources:** W01 / W17

1. Day / sequence	Global Day 152 of 365; calendar-free M06W2D5; optional date 2027-03-27.
2. Exact topic	Path traversal and file upload security
3. Exact subtopics	Canonicalization, traversal sequences, zip slip, file type confusion, content disposition, storage outside web root, size limits and malware scanning
4. Learning objective	Build a safe file-upload workflow from untrusted input
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, Path traversal and File upload topics; choose one Apprentice lab each. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete one lab, then implement safe filename generation, extension/content checks, size cap and storage outside the web root in a local test app. **2.** Standard (~2 h): Complete one lab, then implement safe filename generation, extension/content checks, size cap and storage outside the web root in a local test app. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete one lab, then implement safe filename generation, extension/content checks, size cap and storage outside the web root in a local test app. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	secure-upload.py and tests; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is a MIME type supplied by the client not trustworthy? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Tests reject all malicious samples and no uploaded file is executable Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, Path traversal and File upload topics; choose one Apprentice lab each"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D153 · M06W2D6 · Weekly injection and client-side security review

Phase: Academic month · **Optional date:** 2027-03-28 · **Domain resources:** W02 / W17

1. Day / sequence	Global Day 153 of 365; calendar-free M06W2D6; optional date 2027-03-28.
2. Exact topic	Weekly injection and client-side security review
3. Exact subtopics	SQLi, XSS, CSRF, SSRF, path traversal and file upload; defensive mapping and retrieval
4. Learning objective	Demonstrate that each exploit has a concrete preventive control and validation test
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy Learning Paths `https://portswigger.net/web-security/learning-paths` **Type:** Structured learning paths · **Access:** Free
6. Exact section / lesson locator	PortSwigger Web Security Academy Learning Paths, server-side vulnerabilities path; complete assigned labs only. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a table mapping six vulnerabilities to root cause, control, test and residual risk; retake one failed lab from memory. **2.** Standard (~2 h): Create a table mapping six vulnerabilities to root cause, control, test and residual risk; retake one failed lab from memory. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a table mapping six vulnerabilities to root cause, control, test and residual risk; retake one failed lab from memory. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M6W2-review.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which two vulnerability classes share canonicalization as a root cause? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and every row has a working validation test Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy Learning Paths, server-side vulnerabilities path; complete assigned labs only"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D154 · M06W2D7 · API fundamentals and authorization models

Phase: Academic month · **Optional date:** 2027-03-29 · **Domain resources:** C16 / W01 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 154 of 365; calendar-free M06W2D7; optional date 2027-03-29.
2. Exact topic	API fundamentals and authorization models
3. Exact subtopics	REST/GraphQL basics, resource identifiers, verbs, JSON schemas, pagination, BOLA, BFLA, object property authorization and mass assignment
4. Learning objective	Test an API for object-level authorization using synthetic data
5. Primary lecture / reading + direct URL	OWASP API Security Top 10 `https://owasp.org/API-Security/editions/2023/en/0x11-t10/` **Type:** Reference · **Access:** Free
6. Exact section / lesson locator	OWASP API Security Top 10, API1 BOLA, API3 property authorization and API5 BFLA. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	PortSwigger Web Security Academy `https://portswigger.net/web-security`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Build a small local API with two users and five resources; write tests that prove one user cannot read or modify another's objects — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Build a small local API with two users and five resources; write tests that prove one user cannot read or modify another's objects — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Build a small local API with two users and five resources; write tests that prove one user cannot read or modify another's objects — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	api-authz-tests.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Why must authorization use the authenticated server-side identity rather than a user-supplied ID? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All cross-user tests fail closed and legitimate tests pass Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP API Security Top 10, API1 BOLA, API3 property authorization and API5 BFLA"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Top 10; write a five-line correction; retest next morning with a new 10-minute problem.

Month 06 · Week 3 · daily cards

D155 · M06W3D1 · Rate limiting, input validation and abuse cases

Phase: Academic month · **Optional date:** 2027-03-30 · **Domain resources:** W01 / C15

1. Day / sequence	Global Day 155 of 365; calendar-free M06W3D1; optional date 2027-03-30.
2. Exact topic	Rate limiting, input validation and abuse cases
3. Exact subtopics	Authentication throttling, resource limits, pagination bounds, idempotency, request size, enumeration and business-logic abuse
4. Learning objective	Design abuse controls that preserve legitimate function
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, Rate limiting and Business logic vulnerabilities topics. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Application Security Verification Standard `https://owasp.org/www-project-application-security-verification-standard/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Add rate limits and pagination bounds to the local API; test against a synthetic burst and one business-logic bypass. **2.** Standard (~2 h): Add rate limits and pagination bounds to the local API; test against a synthetic burst and one business-logic bypass. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Add rate limits and pagination bounds to the local API; test against a synthetic burst and one business-logic bypass. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	rate-limit-tests.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can a global rate limit be both too strict and too weak for an API? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Controls are tested and limitations are explained Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, Rate limiting and Business logic vulnerabilities topics"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D156 · M06W3D2 · Secrets management and configuration security

Phase: Academic month · **Optional date:** 2027-03-31 · **Domain resources:** W13 / W17

1. Day / sequence	Global Day 156 of 365; calendar-free M06W3D2; optional date 2027-03-31.
2. Exact topic	Secrets management and configuration security
3. Exact subtopics	Environment variables, secret managers, rotation, .gitignore, entropy, logging redaction, config drift and default credentials
4. Learning objective	Remove secrets from a deliberately unsafe local repository and prevent recurrence
5. Primary lecture / reading + direct URL	GitHub code security documentation `https://docs.github.com/en/code-security` **Type:** Official documentation · **Access:** Free features vary by repository visibility and plan
6. Exact section / lesson locator	GitHub code security documentation, secret scanning and repository security sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a synthetic repository with dummy secrets, remove them from working code/config, add .gitignore, pre-commit-style checks and a rotation plan. **2.** Standard (~2 h): Create a synthetic repository with dummy secrets, remove them from working code/config, add .gitignore, pre-commit-style checks and a rotation plan. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a synthetic repository with dummy secrets, remove them from working code/config, add .gitignore, pre-commit-style checks and a rotation plan. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	secrets-remediation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does deleting a secret from the latest commit not remove it from Git history? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	No secret remains in current files and the plan addresses history/rotation Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "GitHub code security documentation, secret scanning and repository security sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Semgrep documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D157 · M06W3D3 · Secure SDLC and code review gates

Phase: Academic month · **Optional date:** 2027-04-01 · **Domain resources:** P08 / W13

1. Day / sequence	Global Day 157 of 365; calendar-free M06W3D3; optional date 2027-04-01.
2. Exact topic	Secure SDLC and code review gates
3. Exact subtopics	Requirements, threat modelling, secure design, dependencies, code review, SAST/DAST, testing, release and incident feedback
4. Learning objective	Design a small secure development pipeline with measurable gates
5. Primary lecture / reading + direct URL	OWASP Secure Coding Practices Quick Reference Guide `https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/` **Type:** Checklist/reference · **Access:** Free
6. Exact section / lesson locator	OWASP Secure Coding Practices Quick Reference Guide and OWASP ASVS Level 1 selected requirements. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	GitHub code security documentation `https://docs.github.com/en/code-security`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Draw a CI pipeline with at least five security gates; define pass/fail evidence and a risk-acceptance path for each. **2.** Standard (~2 h): Draw a CI pipeline with at least five security gates; define pass/fail evidence and a risk-acceptance path for each. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Draw a CI pipeline with at least five security gates; define pass/fail evidence and a risk-acceptance path for each. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	sdlc-pipeline.svg; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which gate would have detected the most bugs in your Month 4 tool? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Pipeline is realistic for a solo student and each gate has objective criteria Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Secure Coding Practices Quick Reference Guide and OWASP ASVS Level 1 selected requirements"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D158 · M06W3D4 · Dependency and supply-chain security

Phase: Academic month · **Optional date:** 2027-04-02 · **Domain resources:** W12 / W16

1. Day / sequence	Global Day 158 of 365; calendar-free M06W3D4; optional date 2027-04-02.
2. Exact topic	Dependency and supply-chain security
3. Exact subtopics	SBOMs, lockfiles, provenance, pinning, typosquatting, vulnerable dependencies, transitive risk and update policy
4. Learning objective	Triage a synthetic vulnerable dependency and improve repository hygiene
5. Primary lecture / reading + direct URL	OWASP Dependency-Check `https://owasp.org/www-project-dependency-check/` **Type:** Open-source SCA tool · **Access:** Free/open-source
6. Exact section / lesson locator	OWASP Dependency-Check documentation; W15 OpenSSF Scorecard checks. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SLSA specification `https://slsa.dev/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Scan a synthetic project with a deliberately old dependency, triage findings, pin versions, add an SBOM and improve two Scorecard checks. **2.** Standard (~2 h): Scan a synthetic project with a deliberately old dependency, triage findings, pin versions, add an SBOM and improve two Scorecard checks. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Scan a synthetic project with a deliberately old dependency, triage findings, pin versions, add an SBOM and improve two Scorecard checks. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	supply-chain-report.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can a high/critical CVE be unexploitable in your specific usage? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Findings are triaged with context and no blind upgrade without testing Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Dependency-Check documentation; W15 OpenSSF Scorecard checks"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OpenSSF Scorecard; write a five-line correction; retest next morning with a new 10-minute problem.

D159 · M06W3D5 · Weekly API, SDLC and supply-chain review

Phase: Academic month · **Optional date:** 2027-04-03 · **Domain resources:** W13 / C15

1. Day / sequence	Global Day 159 of 365; calendar-free M06W3D5; optional date 2027-04-03.
2. Exact topic	Weekly API, SDLC and supply-chain review
3. Exact subtopics	API authorization, rate limits, validation, secrets, secure SDLC, SAST, SCA and provenance; active recall
4. Learning objective	Demonstrate Month 6 Week 3 competence through a mini secure-release review
5. Primary lecture / reading + direct URL	GitHub code security documentation `https://docs.github.com/en/code-security` **Type:** Official documentation · **Access:** Free features vary by repository visibility and plan
6. Exact section / lesson locator	GitHub code security docs, code scanning, secret scanning and Dependabot sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Application Security Verification Standard `https://owasp.org/www-project-application-security-verification-standard/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Review a synthetic release candidate, decide pass/fail for five gates, and justify one temporary risk acceptance with compensating controls. **2.** Standard (~2 h): Review a synthetic release candidate, decide pass/fail for five gates, and justify one temporary risk acceptance with compensating controls. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Review a synthetic release candidate, decide pass/fail for five gates, and justify one temporary risk acceptance with compensating controls. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M6W3-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which supply-chain risk is not detectable by a vulnerability scanner alone? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and every gate decision has evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "GitHub code security docs, code scanning, secret scanning and Dependabot sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Semgrep documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D160 · M06W3D6 · Secure web application engineering sprint: design

Phase: Academic month · **Optional date:** 2027-04-04 · **Domain resources:** C15 / C17

1. Day / sequence	Global Day 160 of 365; calendar-free M06W3D6; optional date 2027-04-04.
2. Exact topic	Secure web application engineering sprint: design
3. Exact subtopics	Functional requirements, data model, auth model, roles, threat model, trust boundaries, abuse cases and test plan
4. Learning objective	Design a small secure notes API with explicit security requirements
5. Primary lecture / reading + direct URL	OWASP Application Security Verification Standard `https://owasp.org/www-project-application-security-verification-standard/` **Type:** Standard/reference · **Access:** Free
6. Exact section / lesson locator	OWASP ASVS Level 1 requirements V1, V2, V3, V4, V5 and V7. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Threat Modeling community page `https://owasp.org/www-community/Threat_Modeling`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write a specification for a local notes API, including user roles, session policy, object ownership, validation rules and security test cases. **2.** Standard (~2 h): Write a specification for a local notes API, including user roles, session policy, object ownership, validation rules and security test cases. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write a specification for a local notes API, including user roles, session policy, object ownership, validation rules and security test cases. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-08 design.md and threat-model.svg; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which requirement prevents the most likely authorization bug? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Design is complete and every security requirement has a planned test Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP ASVS Level 1 requirements V1, V2, V3, V4, V5 and V7"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Secure Coding Practices Quick Reference Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D161 · M06W3D7 · Secure web application engineering sprint: implementation

Phase: Academic month · **Optional date:** 2027-04-05 · **Domain resources:** W17 / P08 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 161 of 365; calendar-free M06W3D7; optional date 2027-04-05.
2. Exact topic	Secure web application engineering sprint: implementation
3. Exact subtopics	Parameterized queries, password hashing/KDF, session cookies, anti-CSRF, output encoding, rate limiting and structured errors
4. Learning objective	Implement the core API with secure defaults and no secrets in code
5. Primary lecture / reading + direct URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/` **Type:** Official checklist library · **Access:** Free
6. Exact section / lesson locator	OWASP Cheat Sheet Series, Authentication, Session Management, CSRF and SQL Injection Prevention cheat sheets. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Secure Coding Practices Quick Reference Guide `https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Implement registration, login, logout, create/read/update/delete notes, object ownership checks and input validation; use a local database only — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Implement registration, login, logout, create/read/update/delete notes, object ownership checks and input validation; use a local database only — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Implement registration, login, logout, create/read/update/delete notes, object ownership checks and input validation; use a local database only — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-08 source code and migrations; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Why is error handling a security control rather than just a user-experience concern? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All core functions work locally and no sensitive data appears in errors or logs Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Cheat Sheet Series, Authentication, Session Management, CSRF and SQL Injection Prevention cheat sheets"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Application Security Verification Standard; write a five-line correction; retest next morning with a new 10-minute problem.

Month 06 · Week 4 · daily cards

D162 · M06W4D1 · Secure web application engineering sprint: testing

Phase: Academic month · **Optional date:** 2027-04-06 · **Domain resources:** P05 / W14

1. Day / sequence	Global Day 162 of 365; calendar-free M06W4D1; optional date 2027-04-06.
2. Exact topic	Secure web application engineering sprint: testing
3. Exact subtopics	Unit, integration, authorization, injection, XSS, CSRF, SSRF-like fetch controls, dependency scan and negative tests
4. Learning objective	Prove the app resists assigned abuse cases
5. Primary lecture / reading + direct URL	pytest documentation `https://docs.pytest.org/en/stable/` **Type:** Official documentation · **Access:** Free
6. Exact section / lesson locator	pytest documentation and fixtures/parametrization sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Semgrep documentation `https://semgrep.dev/docs/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write at least 20 automated tests, including cross-user access, malicious input, expired session and invalid token; run Semgrep and triage findings. **2.** Standard (~2 h): Write at least 20 automated tests, including cross-user access, malicious input, expired session and invalid token; run Semgrep and triage findings. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write at least 20 automated tests, including cross-user access, malicious input, expired session and invalid token; run Semgrep and triage findings. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-08 test report and scanner output; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which test was most valuable and what bug did it expose? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All tests pass and scanner findings are triaged with evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "pytest documentation and fixtures/parametrization sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Python 3 Official Tutorial; write a five-line correction; retest next morning with a new 10-minute problem.

D163 · M06W4D2 · Local web security assessment of the app

Phase: Academic month · **Optional date:** 2027-04-07 · **Domain resources:** W06 / E01

1. Day / sequence	Global Day 163 of 365; calendar-free M06W4D2; optional date 2027-04-07.
2. Exact topic	Local web security assessment of the app
3. Exact subtopics	Written scope, permitted discovery, enumeration, validation, impact, evidence, remediation and retest
4. Learning objective	Perform an authorized assessment against your own loopback app and fix the findings
5. Primary lecture / reading + direct URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/` **Type:** Testing methodology · **Access:** Free
6. Exact section / lesson locator	OWASP Web Security Testing Guide, relevant sections for authentication, authorization, session and input validation. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a rules-of-engagement document, test five areas of your own local app, record three findings with sanitized evidence, then remediate and retest. **2.** Standard (~2 h): Create a rules-of-engagement document, test five areas of your own local app, record three findings with sanitized evidence, then remediate and retest. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a rules-of-engagement document, test five areas of your own local app, record three findings with sanitized evidence, then remediate and retest. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-09 assessment report; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which finding was a false positive and why did you conclude that? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Scope is explicit, targets are local/owned, and all findings have retest evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Web Security Testing Guide, relevant sections for authentication, authorization, session and input validation"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D164 · M06W4D3 · Dependency and CI security for the capstone

Phase: Academic month · **Optional date:** 2027-04-08 · **Domain resources:** W13 / W14

1. Day / sequence	Global Day 164 of 365; calendar-free M06W4D3; optional date 2027-04-08.
2. Exact topic	Dependency and CI security for the capstone
3. Exact subtopics	Debug mode, default accounts, security headers, CORS, pinned actions, least permissions, secret scanning, code scanning, dependency scanning, SBOM and reproducible builds
4. Learning objective	Harden a GitHub Actions workflow for the secure API repository
5. Primary lecture / reading + direct URL	GitHub code security documentation `https://docs.github.com/en/code-security` **Type:** Official documentation · **Access:** Free features vary by repository visibility and plan
6. Exact section / lesson locator	GitHub Actions security hardening, GITHUB_TOKEN permissions, secrets and third-party action risks. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Semgrep documentation `https://semgrep.dev/docs/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a CI workflow with pinned action SHAs, least privileges, tests, Semgrep and dependency scanning; verify no secrets in logs. **2.** Standard (~2 h): Create a CI workflow with pinned action SHAs, least privileges, tests, Semgrep and dependency scanning; verify no secrets in logs. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a CI workflow with pinned action SHAs, least privileges, tests, Semgrep and dependency scanning; verify no secrets in logs. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	.github/workflows/security.yml and run evidence; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why should third-party actions be pinned to a commit SHA rather than a mutable tag? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Workflow runs and all assigned controls are demonstrably present Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "GitHub Actions security hardening, GITHUB_TOKEN permissions, secrets and third-party action risks"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Semgrep documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D165 · M06W4D4 · Portfolio publication of secure app and assessment

Phase: Academic month · **Optional date:** 2027-04-09 · **Domain resources:** F09 / W13

1. Day / sequence	Global Day 165 of 365; calendar-free M06W4D4; optional date 2027-04-09.
2. Exact topic	Portfolio publication of secure app and assessment
3. Exact subtopics	README, architecture, threat model, secure-design trade-offs, sanitized evidence, tests, limitations and reproduction steps
4. Learning objective	Publish both attacker and defender evidence without leaking secrets
5. Primary lecture / reading + direct URL	Pro Git, 2nd Edition `https://git-scm.com/book/en/v2` **Type:** Free book / official reference · **Access:** Free
6. Exact section / lesson locator	Pro Git Chapters 2-3 and GitHub Docs README conventions linked from F09. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	GitHub code security documentation `https://docs.github.com/en/code-security`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Finalize PRJ-08 and PRJ-09, add setup scripts, sanitized screenshots, test instructions and a lessons-learned section. **2.** Standard (~2 h): Finalize PRJ-08 and PRJ-09, add setup scripts, sanitized screenshots, test instructions and a lessons-learned section. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Finalize PRJ-08 and PRJ-09, add setup scripts, sanitized screenshots, test instructions and a lessons-learned section. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	published repositories and release tags; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which README section proves independent reasoning rather than tutorial copying? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Portfolio checklist passes and no credentials, real personal data or active exploit endpoints are published Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Pro Git Chapters 2-3 and GitHub Docs README conventions linked from F09"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Python for Everybody; write a five-line correction; retest next morning with a new 10-minute problem.

D166 · M06W4D5 · Month 6 practical examination and milestone gate

Phase: Academic month · **Optional date:** 2027-04-10 · **Domain resources:** W01 / C15

1. Day / sequence	Global Day 166 of 365; calendar-free M06W4D5; optional date 2027-04-10.
2. Exact topic	Month 6 practical examination and milestone gate
3. Exact subtopics	Web/API security, secure coding, OWASP Top 10, defensive fixes, SDLC and supply chain; practical scenario
4. Learning objective	Demonstrate secure web engineering and authorized assessment competence
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy all-labs index; select only Apprentice labs for revision. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Application Security Verification Standard `https://owasp.org/www-project-application-security-verification-standard/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete a 120-minute practical: find and fix two vulnerabilities in an unseen local snippet, design API authorization controls, and write a remediation report. **2.** Standard (~2 h): Complete a 120-minute practical: find and fix two vulnerabilities in an unseen local snippet, design API authorization controls, and write a remediation report. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete a 120-minute practical: find and fix two vulnerabilities in an unseen local snippet, design API authorization controls, and write a remediation report. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M6-assessment.pdf and scorecard; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which fix addresses the root cause and which only blocks one payload? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100, milestone gate passed, practical at least 18/25 and safety at least 9/10 Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy all-labs index; select only Apprentice labs for revision"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D167 · M06W4D6 · Monthly review and gap repairs

Phase: Academic month · **Optional date:** 2027-04-11 · **Domain resources:** W17 / W06

1. Day / sequence	Global Day 167 of 365; calendar-free M06W4D6; optional date 2027-04-11.
2. Exact topic	Monthly review and gap repairs
3. Exact subtopics	Injection/XSS/CSRF/SSRF root causes, authorization, session controls, headers, secrets and CI gates; active recall
4. Learning objective	Repair Month 6 gaps and prepare ethical testing methodology
5. Primary lecture / reading + direct URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/` **Type:** Official checklist library · **Access:** Free
6. Exact section / lesson locator	OWASP Cheat Sheet Series selected cheat sheets for your three weakest topics. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Rework failed assessment items with new code examples, add missing tests, and review the OWASP WSTG and NIST SP 800-115 structure. **2.** Standard (~2 h): Rework failed assessment items with new code examples, add missing tests, and review the OWASP WSTG and NIST SP 800-115 structure. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Rework failed assessment items with new code examples, add missing tests, and review the OWASP WSTG and NIST SP 800-115 structure. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M6-review.md and retest score; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which web vulnerability class is still easy to identify but hard to remediate correctly? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Retest score at least 80 percent and each gap has a new defensive test Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Cheat Sheet Series selected cheat sheets for your three weakest topics"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Application Security Verification Standard; write a five-line correction; retest next morning with a new 10-minute problem.

D168 · M06W4D7 · Spaced revision, recovery and Month 7 preview

Phase: Academic month · **Optional date:** 2027-04-12 · **Domain resources:** W01 / E01 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 168 of 365; calendar-free M06W4D7; optional date 2027-04-12.
2. Exact topic	Spaced revision, recovery and Month 7 preview
3. Exact subtopics	Secure headers, auth/authz, injection, XSS, CSRF, SSRF, file upload, API and supply-chain retrieval; lighter workload
4. Learning objective	Preserve web-security knowledge and prepare authorized assessment rules
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy dashboard for spaced lab review, one old Apprentice lab only. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, solve one old lab without notes, read the first sections of NIST SP 800-115, and rest — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, solve one old lab without notes, read the first sections of NIST SP 800-115, and rest — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, solve one old lab without notes, read the first sections of NIST SP 800-115, and rest — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M6-consolidation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: How would you explain the difference between a vulnerability, an exploit and a finding to a client? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Retrieval score is recorded and explanation is accurate Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy dashboard for spaced lab review, one old Apprentice lab only"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

Month 07 — Ethical testing, vulnerability assessment and authorized labs

Days D169-D196. Each day has the same 13-field structure. Use the Core, Standard or Intensive track; the learning objective does not change. Day 7 of each week is lighter by design.

Week	Daily topics
Week 1	D1: Ethics, law and written authorization D2: Rules of engagement and assessment planning D3: Asset inventory and permitted discovery D4: Threat modelling for an authorized assessment D5: Discovery and enumeration in an isolated lab D6: Vulnerability scanning concepts and validation D7: Weekly ethical testing review and scope gate
Week 2	D1: Web vulnerability validation in PortSwigger labs D2: Network service validation in a local VM lab D3: Risk prioritization beyond CVSS D4: Evidence collection and chain of custody D5: Remediation recommendations that engineers can implement D6: Weekly validation and remediation review D7: Retesting and closure criteria
Week 3	D1: Technical report writing: executive summary and findings D2: Professional communication and defensive debrief D3: Responsible disclosure and coordinated vulnerability handling D4: Common penetration-testing pitfalls and professional limits D5: Weekly report-writing and ethics review D6: Authorized assessment capstone: planning and discovery D7: Authorized assessment capstone: execution and evidence
Week 4	D1: Authorized assessment capstone: analysis and report D2: Authorized assessment capstone: remediation and retest D3: Portfolio publication and independent reflection D4: Certification and specialization decision point D5: Month 7 practical examination and mastery gate D6: Monthly review and gap repairs D7: Spaced revision, recovery and Month 8 preview

> **Gate:** score the Month 7 assessment using the 100-point rubric in Volume 6. If score <70 or safety <9/10, follow the six-step repair protocol before advancing.

Month 07 · Week 1 · daily cards

D169 · M07W1D1 · Ethics, law and written authorization

Phase: Academic month · **Optional date:** 2027-04-13 · **Domain resources:** E01 / E05

1. Day / sequence	Global Day 169 of 365; calendar-free M07W1D1; optional date 2027-04-13.
2. Exact topic	Ethics, law and written authorization
3. Exact subtopics	Ownership, consent, written scope, jurisdiction, computer-misuse concepts, privacy, professional codes and consequences
4. Learning objective	Explain why authorization is a technical prerequisite, not a formality
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115, planning and legal/ethical considerations sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	HackerOne Disclosure Guidelines `https://www.hackerone.com/disclosure-guidelines`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write a one-page ethics statement and a written authorization template for a fictional lab owned by the student. **2.** Standard (~2 h): Write a one-page ethics statement and a written authorization template for a fictional lab owned by the student. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write a one-page ethics statement and a written authorization template for a fictional lab owned by the student. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	ethics-statement.md and authorization-template.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which three facts must be present before any active scanning begins? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Documents define owner, assets, time, permitted actions, emergency contact and stop conditions Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115, planning and legal/ethical considerations sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D170 · M07W1D2 · Rules of engagement and assessment planning

Phase: Academic month · **Optional date:** 2027-04-14 · **Domain resources:** E01 / C26

1. Day / sequence	Global Day 170 of 365; calendar-free M07W1D2; optional date 2027-04-14.
2. Exact topic	Rules of engagement and assessment planning
3. Exact subtopics	Objectives, in-scope/out-of-scope assets, testing windows, allowed techniques, prohibited actions, data handling, escalation and abort criteria
4. Learning objective	Build a complete RoE for an isolated student lab
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115, assessment planning and rules of behaviour sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-30 Revision 1 `https://csrc.nist.gov/pubs/sp/800/30/r1/final`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a detailed RoE for a two-VM local lab, including evidence handling, rate limits and destruction/cleanup steps. **2.** Standard (~2 h): Create a detailed RoE for a two-VM local lab, including evidence handling, rate limits and destruction/cleanup steps. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a detailed RoE for a two-VM local lab, including evidence handling, rate limits and destruction/cleanup steps. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	rules-of-engagement.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which clause protects availability if a scanner causes service failure? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	RoE is unambiguous and includes a specific stop condition and contact path Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115, assessment planning and rules of behaviour sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D171 · M07W1D3 · Asset inventory and permitted discovery

Phase: Academic month · **Optional date:** 2027-04-15 · **Domain resources:** C21 / N09

1. Day / sequence	Global Day 171 of 365; calendar-free M07W1D3; optional date 2027-04-15.
2. Exact topic	Asset inventory and permitted discovery
3. Exact subtopics	Asset register, IP ranges, domains, owners, services, data sensitivity, passive discovery and active confirmation
4. Learning objective	Build an asset inventory before any testing activity
5. Primary lecture / reading + direct URL	CIS Controls Version 8 `https://www.cisecurity.org/controls/v8` **Type:** Best-practice controls · **Access:** Free overview; some tools paid
6. Exact section / lesson locator	CIS Controls Version 8, controls on enterprise/data asset inventory. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Nmap Reference Guide `https://nmap.org/book/man.html`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Inventory your own lab VMs and containers, record IPs, ports, services, owner and authorization status, then verify with one passive and one active method. **2.** Standard (~2 h): Inventory your own lab VMs and containers, record IPs, ports, services, owner and authorization status, then verify with one passive and one active method. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Inventory your own lab VMs and containers, record IPs, ports, services, owner and authorization status, then verify with one passive and one active method. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	asset-inventory.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is an unknown asset outside the inventory unsafe to scan even if it is nearby? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All active discovery targets appear in the signed scope/inventory Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CIS Controls Version 8, controls on enterprise/data asset inventory"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D172 · M07W1D4 · Threat modelling for an authorized assessment

Phase: Academic month · **Optional date:** 2027-04-16 · **Domain resources:** C17 / C18

1. Day / sequence	Global Day 172 of 365; calendar-free M07W1D4; optional date 2027-04-16.
2. Exact topic	Threat modelling for an authorized assessment
3. Exact subtopics	Attack trees, trust boundaries, likely threat actors, abuse cases, assumptions and test hypotheses
4. Learning objective	Turn scope into prioritized test hypotheses
5. Primary lecture / reading + direct URL	OWASP Threat Modeling community page `https://owasp.org/www-community/Threat_Modeling` **Type:** Reference/process · **Access:** Free
6. Exact section / lesson locator	OWASP Threat Modeling community page and W06 OWASP WSTG information-gathering sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Produce an attack tree for a fictional local web app and derive five testable hypotheses with required evidence. **2.** Standard (~2 h): Produce an attack tree for a fictional local web app and derive five testable hypotheses with required evidence. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Produce an attack tree for a fictional local web app and derive five testable hypotheses with required evidence. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	attack-tree.svg and hypotheses.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which hypothesis can be disproved with a single benign request? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Each hypothesis has a prediction and a safe falsification test Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Threat Modeling community page and W06 OWASP WSTG information-gathering sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE ATT&CK; write a five-line correction; retest next morning with a new 10-minute problem.

D173 · M07W1D5 · Discovery and enumeration in an isolated lab

Phase: Academic month · **Optional date:** 2027-04-17 · **Domain resources:** N09 / N08

1. Day / sequence	Global Day 173 of 365; calendar-free M07W1D5; optional date 2027-04-17.
2. Exact topic	Discovery and enumeration in an isolated lab
3. Exact subtopics	Host discovery, port/service enumeration, banner grabbing, version mapping, OS fingerprinting, DNS and web-content discovery
4. Learning objective	Perform authorized discovery without exploiting anything yet
5. Primary lecture / reading + direct URL	Nmap Reference Guide `https://nmap.org/book/man.html` **Type:** Official documentation · **Access:** Free
6. Exact section / lesson locator	Nmap Reference Guide, host discovery, port scanning, service/version detection and output sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	tcpdump manual page `https://www.tcpdump.org/manpages/tcpdump.1.html`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Scan only an isolated lab VM; save raw output and a normalized service table; capture packets for one scan type. **2.** Standard (~2 h): Scan only an isolated lab VM; save raw output and a normalized service table; capture packets for one scan type. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Scan only an isolated lab VM; save raw output and a normalized service table; capture packets for one scan type. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	discovery-evidence/; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which result is ambiguous and what second observation would resolve it? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Written scope is attached, output is preserved, and ambiguous results are labelled Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Nmap Reference Guide, host discovery, port scanning, service/version detection and output sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup RFC 9293: Transmission Control Protocol; write a five-line correction; retest next morning with a new 10-minute problem.

D174 · M07W1D6 · Vulnerability scanning concepts and validation

Phase: Academic month · **Optional date:** 2027-04-18 · **Domain resources:** W07 / E08

1. Day / sequence	Global Day 174 of 365; calendar-free M07W1D6; optional date 2027-04-18.
2. Exact topic	Vulnerability scanning concepts and validation
3. Exact subtopics	Scanner architecture, signatures, authenticated/unauthenticated scans, false positives/negatives, CVE/CVSS and safe validation
4. Learning objective	Distinguish a scanner alert from a validated vulnerability
5. Primary lecture / reading + direct URL	OWASP ZAP documentation `https://www.zaproxy.org/docs/` **Type:** Official tool docs · **Access:** Free/open-source
6. Exact section / lesson locator	OWASP ZAP documentation, passive/active scanning and alert interpretation. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NVD `https://nvd.nist.gov/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Run a passive/local scan on an intentionally vulnerable local app, choose three alerts, and write benign validation steps that prove or disprove each. **2.** Standard (~2 h): Run a passive/local scan on an intentionally vulnerable local app, choose three alerts, and write benign validation steps that prove or disprove each. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Run a passive/local scan on an intentionally vulnerable local app, choose three alerts, and write benign validation steps that prove or disprove each. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	vulnerability-validation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is banner version alone insufficient proof of exploitability? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Each alert has evidence, confidence and a safe validation decision Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP ZAP documentation, passive/active scanning and alert interpretation"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Burp Suite documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D175 · M07W1D7 · Weekly ethical testing review and scope gate

Phase: Academic month · **Optional date:** 2027-04-19 · **Domain resources:** E01 / C26 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 175 of 365; calendar-free M07W1D7; optional date 2027-04-19.
2. Exact topic	Weekly ethical testing review and scope gate
3. Exact subtopics	Ethics, law, RoE, asset inventory, threat modelling, discovery, enumeration and scanner interpretation
4. Learning objective	Pass a scope-and-safety gate before any exploitation labs
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115, technical assessment planning and validation sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-30 Revision 1 `https://csrc.nist.gov/pubs/sp/800/30/r1/final`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute case with five scope traps; write decisions and justify each stop/continue choice — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute case with five scope traps; write decisions and justify each stop/continue choice — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute case with five scope traps; write decisions and justify each stop/continue choice — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M7W1-scope-gate.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which action is legal/authorized but still unsafe for availability? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 80/100 on safety and no unauthorized target appears in any evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115, technical assessment planning and validation sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

Month 07 · Week 2 · daily cards

D176 · M07W2D1 · Web vulnerability validation in PortSwigger labs

Phase: Academic month · **Optional date:** 2027-04-20 · **Domain resources:** W01 / W06

1. Day / sequence	Global Day 176 of 365; calendar-free M07W2D1; optional date 2027-04-20.
2. Exact topic	Web vulnerability validation in PortSwigger labs
3. Exact subtopics	Reproducible request/response evidence, impact, root cause, minimal proof of concept and avoiding collateral actions
4. Learning objective	Validate one vulnerability class without using walkthroughs
5. Primary lecture / reading + direct URL	PortSwigger Web Security Academy `https://portswigger.net/web-security` **Type:** Free interactive academy · **Access:** Free account required
6. Exact section / lesson locator	PortSwigger Web Security Academy, SQL injection or XSS Apprentice labs. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Choose one unseen Apprentice lab, solve it with a documented hypothesis chain, and save sanitized request/response evidence. **2.** Standard (~2 h): Choose one unseen Apprentice lab, solve it with a documented hypothesis chain, and save sanitized request/response evidence. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Choose one unseen Apprentice lab, solve it with a documented hypothesis chain, and save sanitized request/response evidence. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	lab-validation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What observation changed your hypothesis from possible to confirmed? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Lab is solved within the authorized Academy and evidence is reproducible Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "PortSwigger Web Security Academy, SQL injection or XSS Apprentice labs"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy Learning Paths; write a five-line correction; retest next morning with a new 10-minute problem.

D177 · M07W2D2 · Network service validation in a local VM lab

Phase: Academic month · **Optional date:** 2027-04-21 · **Domain resources:** N09 / C18

1. Day / sequence	Global Day 177 of 365; calendar-free M07W2D2; optional date 2027-04-21.
2. Exact topic	Network service validation in a local VM lab
3. Exact subtopics	Service version, configuration weakness, default credentials, unnecessary services and controlled proof of impact
4. Learning objective	Validate a synthetic service finding with minimal privileged actions
5. Primary lecture / reading + direct URL	Nmap Reference Guide `https://nmap.org/book/man.html` **Type:** Official documentation · **Access:** Free
6. Exact section / lesson locator	Nmap Reference Guide service/version detection and NSE safety sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: In an isolated local VM, identify one intentionally weak service, confirm the issue with benign evidence, and stop before persistence or lateral movement. **2.** Standard (~2 h): In an isolated local VM, identify one intentionally weak service, confirm the issue with benign evidence, and stop before persistence or lateral movement. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): In an isolated local VM, identify one intentionally weak service, confirm the issue with benign evidence, and stop before persistence or lateral movement. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	service-finding.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What is the least invasive evidence that proves the weakness? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Evidence is sufficient, no destructive action occurs, and findings are reproducible Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Nmap Reference Guide service/version detection and NSE safety sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup RFC 9293: Transmission Control Protocol; write a five-line correction; retest next morning with a new 10-minute problem.

D178 · M07W2D3 · Risk prioritization beyond CVSS

Phase: Academic month · **Optional date:** 2027-04-22 · **Domain resources:** E06 / B18

1. Day / sequence	Global Day 178 of 365; calendar-free M07W2D3; optional date 2027-04-22.
2. Exact topic	Risk prioritization beyond CVSS
3. Exact subtopics	CVSS base/temporal/environmental, EPSS-like concepts, KEV, asset criticality, exposure, compensating controls and business context
4. Learning objective	Rank five findings with explicit reasons and uncertainty
5. Primary lecture / reading + direct URL	FIRST CVSS specification `https://www.first.org/cvss/` **Type:** Scoring standard · **Access:** Free
6. Exact section / lesson locator	FIRST CVSS specification, calculator and metric groups. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CISA Known Exploited Vulnerabilities Catalog `https://www.cisa.gov/known-exploited-vulnerabilities-catalog`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Score five synthetic findings, then re-rank them after learning asset criticality and compensating controls; explain every change. **2.** Standard (~2 h): Score five synthetic findings, then re-rank them after learning asset criticality and compensating controls; explain every change. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Score five synthetic findings, then re-rank them after learning asset criticality and compensating controls; explain every change. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	finding-prioritization.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can a critical CVSS score be lower priority than a medium exploited-in-the-wild bug? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Rankings are consistent with the stated scenario and uncertainty is documented Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "FIRST CVSS specification, calculator and metric groups"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NVD; write a five-line correction; retest next morning with a new 10-minute problem.

D179 · M07W2D4 · Evidence collection and chain of custody

Phase: Academic month · **Optional date:** 2027-04-23 · **Domain resources:** E01 / F09

1. Day / sequence	Global Day 179 of 365; calendar-free M07W2D4; optional date 2027-04-23.
2. Exact topic	Evidence collection and chain of custody
3. Exact subtopics	Screenshots, raw logs, timestamps, hashes, tool versions, command line, provenance, sanitization and evidence manifest
4. Learning objective	Build a defensible evidence package for a synthetic finding
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115 post-test activities and reporting sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Pro Git, 2nd Edition `https://git-scm.com/book/en/v2`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create an evidence bundle for one local lab finding with hashes, timestamps, tool versions, raw output and a README manifest. **2.** Standard (~2 h): Create an evidence bundle for one local lab finding with hashes, timestamps, tool versions, raw output and a README manifest. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create an evidence bundle for one local lab finding with hashes, timestamps, tool versions, raw output and a README manifest. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	evidence-bundle/ with SHA-256 manifest; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which detail would make the evidence inadmissible or unconvincing to a reviewer? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Manifest verifies all files and no personal/unauthorized data is present Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115 post-test activities and reporting sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D180 · M07W2D5 · Remediation recommendations that engineers can implement

Phase: Academic month · **Optional date:** 2027-04-24 · **Domain resources:** W17 / P08

1. Day / sequence	Global Day 180 of 365; calendar-free M07W2D5; optional date 2027-04-24.
2. Exact topic	Remediation recommendations that engineers can implement
3. Exact subtopics	Root cause, configuration/code fix, compensating control, priority, owner, test, rollback and residual risk
4. Learning objective	Convert an offensive finding into an actionable defensive fix
5. Primary lecture / reading + direct URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/` **Type:** Official checklist library · **Access:** Free
6. Exact section / lesson locator	OWASP Cheat Sheet Series matching the assigned vulnerability. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Secure Coding Practices Quick Reference Guide `https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write three remediation tickets for one finding at code, configuration and architecture levels; include acceptance tests. **2.** Standard (~2 h): Write three remediation tickets for one finding at code, configuration and architecture levels; include acceptance tests. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write three remediation tickets for one finding at code, configuration and architecture levels; include acceptance tests. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	remediation-tickets.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is patch the software an incomplete recommendation? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Each ticket has owner, test, rollback and residual risk Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Cheat Sheet Series matching the assigned vulnerability"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Application Security Verification Standard; write a five-line correction; retest next morning with a new 10-minute problem.

D181 · M07W2D6 · Weekly validation and remediation review

Phase: Academic month · **Optional date:** 2027-04-25 · **Domain resources:** E06 / W17

1. Day / sequence	Global Day 181 of 365; calendar-free M07W2D6; optional date 2027-04-25.
2. Exact topic	Weekly validation and remediation review
3. Exact subtopics	Discovery, scanner interpretation, web/service validation, CVSS, evidence and remediation; active recall
4. Learning objective	Demonstrate Month 7 Week 2 competence with a synthetic finding pack
5. Primary lecture / reading + direct URL	FIRST CVSS specification `https://www.first.org/cvss/` **Type:** Scoring standard · **Access:** Free
6. Exact section / lesson locator	FIRST CVSS and E08 NVD/CVE pages for one sample finding. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Receive three synthetic findings, validate evidence, prioritize, write remediations and identify one false positive. **2.** Standard (~2 h): Receive three synthetic findings, validate evidence, prioritize, write remediations and identify one false positive. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Receive three synthetic findings, validate evidence, prioritize, write remediations and identify one false positive. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M7W2-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which finding lacks enough evidence to justify a high-confidence conclusion? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and every conclusion has evidence and confidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "FIRST CVSS and E08 NVD/CVE pages for one sample finding"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NVD; write a five-line correction; retest next morning with a new 10-minute problem.

D182 · M07W2D7 · Retesting and closure criteria

Phase: Academic month · **Optional date:** 2027-04-26 · **Domain resources:** W06 / P05 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 182 of 365; calendar-free M07W2D7; optional date 2027-04-26.
2. Exact topic	Retesting and closure criteria
3. Exact subtopics	Reproduce original evidence, verify fix, regression-test surrounding functions, detect workaround bypass and update status
4. Learning objective	Design a retest that could fail even after a patch appears applied
5. Primary lecture / reading + direct URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/` **Type:** Testing methodology · **Access:** Free
6. Exact section / lesson locator	OWASP WSTG reporting and verification sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	pytest documentation `https://docs.pytest.org/en/stable/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — For one local remediated bug, write three retest cases: original payload, variant and functional regression; record pass/fail and residual risk — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — For one local remediated bug, write three retest cases: original payload, variant and functional regression; record pass/fail and residual risk — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — For one local remediated bug, write three retest cases: original payload, variant and functional regression; record pass/fail and residual risk — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	retest-report.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Why can a WAF block one payload while the underlying vulnerability remains? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Retest distinguishes blocked symptom from fixed root cause Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP WSTG reporting and verification sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

Month 07 · Week 3 · daily cards

D183 · M07W3D1 · Technical report writing: executive summary and findings

Phase: Academic month · **Optional date:** 2027-04-27 · **Domain resources:** W06 / E01

1. Day / sequence	Global Day 183 of 365; calendar-free M07W3D1; optional date 2027-04-27.
2. Exact topic	Technical report writing: executive summary and findings
3. Exact subtopics	Audience, scope, methodology, risk rating, evidence, impact, likelihood, recommendation and appendices
4. Learning objective	Write a professional report that a developer and manager can both use
5. Primary lecture / reading + direct URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/` **Type:** Testing methodology · **Access:** Free
6. Exact section / lesson locator	OWASP Web Security Testing Guide, reporting section and report structure. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Draft a five-page report for a fictional local assessment with three findings and one false positive. **2.** Standard (~2 h): Draft a five-page report for a fictional local assessment with three findings and one false positive. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Draft a five-page report for a fictional local assessment with three findings and one false positive. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	assessment-report-draft.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which sentence confuses observation with interpretation? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Report separates facts, interpretation and recommendation and scores at least 70/100 Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Web Security Testing Guide, reporting section and report structure"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D184 · M07W3D2 · Professional communication and defensive debrief

Phase: Academic month · **Optional date:** 2027-04-28 · **Domain resources:** E01 / C06

1. Day / sequence	Global Day 184 of 365; calendar-free M07W3D2; optional date 2027-04-28.
2. Exact topic	Professional communication and defensive debrief
3. Exact subtopics	Findings walkthrough, uncertainty, disagreement, remediation negotiation, non-blaming language and follow-up
4. Learning objective	Defend conclusions using evidence without exaggeration
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115 reporting and post-test activities. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST Cybersecurity Framework 2.0 `https://www.nist.gov/cyberframework`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Conduct a 20-minute recorded self-presentation or written Q&A that answers five skeptical stakeholder questions. **2.** Standard (~2 h): Conduct a 20-minute recorded self-presentation or written Q&A that answers five skeptical stakeholder questions. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Conduct a 20-minute recorded self-presentation or written Q&A that answers five skeptical stakeholder questions. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	debrief-notes.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which stakeholder concern reveals a missing business-context fact? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Answers are concise, honest and cite specific evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115 reporting and post-test activities"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D185 · M07W3D3 · Responsible disclosure and coordinated vulnerability handling

Phase: Academic month · **Optional date:** 2027-04-29 · **Domain resources:** E05 / E08

1. Day / sequence	Global Day 185 of 365; calendar-free M07W3D3; optional date 2027-04-29.
2. Exact topic	Responsible disclosure and coordinated vulnerability handling
3. Exact subtopics	Disclosure policy, safe harbour, private reporting, timelines, embargo, CVE request, vendor communication and public write-up ethics
4. Learning objective	Draft a disclosure timeline for a synthetic finding
5. Primary lecture / reading + direct URL	HackerOne Disclosure Guidelines `https://www.hackerone.com/disclosure-guidelines` **Type:** Responsible disclosure guidance · **Access:** Free
6. Exact section / lesson locator	HackerOne Disclosure Guidelines and E07 CVE Program information. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NVD `https://nvd.nist.gov/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a synthetic disclosure email, timeline and post-fix write-up; explicitly state that no real target was tested. **2.** Standard (~2 h): Create a synthetic disclosure email, timeline and post-fix write-up; explicitly state that no real target was tested. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a synthetic disclosure email, timeline and post-fix write-up; explicitly state that no real target was tested. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	disclosure-pack.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why should a public write-up wait for a fix or agreed disclosure date? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All documents are synthetic and safe harbour/authorization boundaries are clear Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "HackerOne Disclosure Guidelines and E07 CVE Program information"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup FIRST CVSS specification; write a five-line correction; retest next morning with a new 10-minute problem.

D186 · M07W3D4 · Common penetration-testing pitfalls and professional limits

Phase: Academic month · **Optional date:** 2027-04-30 · **Domain resources:** E01 / E05

1. Day / sequence	Global Day 186 of 365; calendar-free M07W3D4; optional date 2027-04-30.
2. Exact topic	Common penetration-testing pitfalls and professional limits
3. Exact subtopics	Scanner dependence, scope creep, stale objectives, destructive proof, credential exposure, unsupported claims and report inflation
4. Learning objective	Audit an intentionally bad assessment report and correct it
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115 and W06 WSTG methodology sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	HackerOne Disclosure Guidelines `https://www.hackerone.com/disclosure-guidelines`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Review a synthetic report containing ten errors; correct each with evidence, ethical reasoning or clearer language. **2.** Standard (~2 h): Review a synthetic report containing ten errors; correct each with evidence, ethical reasoning or clearer language. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Review a synthetic report containing ten errors; correct each with evidence, ethical reasoning or clearer language. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	report-audit.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which error could cause legal or operational harm? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All ten errors are found and corrections are defensible Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115 and W06 WSTG methodology sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D187 · M07W3D5 · Weekly report-writing and ethics review

Phase: Academic month · **Optional date:** 2027-05-01 · **Domain resources:** W06 / E05

1. Day / sequence	Global Day 187 of 365; calendar-free M07W3D5; optional date 2027-05-01.
2. Exact topic	Weekly report-writing and ethics review
3. Exact subtopics	Retesting, reporting, communication, disclosure, CVE/CVSS and professional limits; peer-style review
4. Learning objective	Demonstrate Month 7 Week 3 competence through an integrated reporting scenario
5. Primary lecture / reading + direct URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/` **Type:** Testing methodology · **Access:** Free
6. Exact section / lesson locator	OWASP WSTG reporting appendix and E06 FIRST CVSS examples. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	HackerOne Disclosure Guidelines `https://www.hackerone.com/disclosure-guidelines`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete a 90-minute scenario: validate, score, report and disclose two synthetic findings under time limits. **2.** Standard (~2 h): Complete a 90-minute scenario: validate, score, report and disclose two synthetic findings under time limits. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete a 90-minute scenario: validate, score, report and disclose two synthetic findings under time limits. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M7W3-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: How would you phrase uncertainty without weakening a real risk? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and safety/ethics section at least 9/10 Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP WSTG reporting appendix and E06 FIRST CVSS examples"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D188 · M07W3D6 · Authorized assessment capstone: planning and discovery

Phase: Academic month · **Optional date:** 2027-05-02 · **Domain resources:** E01 / C21

1. Day / sequence	Global Day 188 of 365; calendar-free M07W3D6; optional date 2027-05-02.
2. Exact topic	Authorized assessment capstone: planning and discovery
3. Exact subtopics	Scoping, RoE, asset inventory, threat model, discovery plan and evidence manifest
4. Learning objective	Plan an end-to-end assessment of your own isolated lab
5. Primary lecture / reading + direct URL	NIST SP 800-115 https://csrc.nist.gov/pubs/sp/800/115/final **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115 full assessment workflow. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CIS Controls Version 8 https://www.cisecurity.org/controls/v8
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a complete assessment plan for two local VMs and one vulnerable web app, with signed scope, timeline and success criteria. **2.** Standard (~2 h): Create a complete assessment plan for two local VMs and one vulnerable web app, with signed scope, timeline and success criteria. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a complete assessment plan for two local VMs and one vulnerable web app, with signed scope, timeline and success criteria. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-10/plan/; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which asset or technique is explicitly out of scope and why? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Plan passes the scope gate and all targets are owned/isolated Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115 full assessment workflow"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D189 · M07W3D7 · Authorized assessment capstone: execution and evidence

Phase: Academic month · **Optional date:** 2027-05-03 · **Domain resources:** N09 / W06 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 189 of 365; calendar-free M07W3D7; optional date 2027-05-03.
2. Exact topic	Authorized assessment capstone: execution and evidence
3. Exact subtopics	Discovery, enumeration, vulnerability validation, evidence preservation and minimal impact testing
4. Learning objective	Execute the planned assessment under controlled conditions
5. Primary lecture / reading + direct URL	Nmap Reference Guide `https://nmap.org/book/man.html` **Type:** Official documentation · **Access:** Free
6. Exact section / lesson locator	Nmap Reference Guide for authorized scanning; W05 Burp Suite scope documentation for local web testing. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Perform only in-scope tests, collect raw evidence, stop at proof of vulnerability, and record every command/request in a timeline — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Perform only in-scope tests, collect raw evidence, stop at proof of vulnerability, and record every command/request in a timeline — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Perform only in-scope tests, collect raw evidence, stop at proof of vulnerability, and record every command/request in a timeline — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-10/evidence/; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which test caused an unexpected service impact and how did you respond? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Timeline is complete and no out-of-scope or destructive action is present Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Nmap Reference Guide for authorized scanning; W05 Burp Suite scope documentation for local web testing"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup RFC 9293: Transmission Control Protocol; write a five-line correction; retest next morning with a new 10-minute problem.

Month 07 · Week 4 · daily cards

D190 · M07W4D1 · Authorized assessment capstone: analysis and report

Phase: Academic month · **Optional date:** 2027-05-04 · **Domain resources:** W06 / W17

1. Day / sequence	Global Day 190 of 365; calendar-free M07W4D1; optional date 2027-05-04.
2. Exact topic	Authorized assessment capstone: analysis and report
3. Exact subtopics	Root cause, risk, impact, evidence correlation, false positives, remediation and retest
4. Learning objective	Produce a defensible assessment report with prioritized recommendations
5. Primary lecture / reading + direct URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/` **Type:** Testing methodology · **Access:** Free
6. Exact section / lesson locator	OWASP WSTG reporting structure and E06 FIRST CVSS specification. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write an eight-page report, include an executive summary, three findings with evidence, one rejected false positive and a remediation roadmap. **2.** Standard (~2 h): Write an eight-page report, include an executive summary, three findings with evidence, one rejected false positive and a remediation roadmap. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write an eight-page report, include an executive summary, three findings with evidence, one rejected false positive and a remediation roadmap. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-10/report.pdf; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which finding's evidence is strongest and which is most uncertain? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Report passes the 100-point rubric and no proprietary or real personal data is exposed Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP WSTG reporting structure and E06 FIRST CVSS specification"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup PortSwigger Web Security Academy; write a five-line correction; retest next morning with a new 10-minute problem.

D191 · M07W4D2 · Authorized assessment capstone: remediation and retest

Phase: Academic month · **Optional date:** 2027-05-05 · **Domain resources:** W17 / P05

1. Day / sequence	Global Day 191 of 365; calendar-free M07W4D2; optional date 2027-05-05.
2. Exact topic	Authorized assessment capstone: remediation and retest
3. Exact subtopics	Fixes, verification, regression testing, residual risk and client-style handover
4. Learning objective	Prove that remediation closed the root cause without breaking functionality
5. Primary lecture / reading + direct URL	OWASP Cheat Sheet Series `https://cheatsheetseries.owasp.org/` **Type:** Official checklist library · **Access:** Free
6. Exact section / lesson locator	OWASP Cheat Sheet Series for each selected finding. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	pytest documentation `https://docs.pytest.org/en/stable/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Implement fixes in the local lab, rerun the original and variant tests, check functional regression, and write a closure memo. **2.** Standard (~2 h): Implement fixes in the local lab, rerun the original and variant tests, check functional regression, and write a closure memo. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Implement fixes in the local lab, rerun the original and variant tests, check functional regression, and write a closure memo. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-10/retest-report.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What evidence proves root-cause closure rather than payload filtering? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All assigned findings are retested and closure criteria are explicit Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "OWASP Cheat Sheet Series for each selected finding"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Application Security Verification Standard; write a five-line correction; retest next morning with a new 10-minute problem.

D192 · M07W4D3 · Portfolio publication and independent reflection

Phase: Academic month · **Optional date:** 2027-05-06 · **Domain resources:** F09 / W13

1. Day / sequence	Global Day 192 of 365; calendar-free M07W4D3; optional date 2027-05-06.
2. Exact topic	Portfolio publication and independent reflection
3. Exact subtopics	Sanitization, scope statement, limitations, ethical boundaries, evidence redaction and independent contribution
4. Learning objective	Publish a professional portfolio case study from the assessment
5. Primary lecture / reading + direct URL	Pro Git, 2nd Edition `https://git-scm.com/book/en/v2` **Type:** Free book / official reference · **Access:** Free
6. Exact section / lesson locator	Pro Git Chapters 2-3 and GitHub security docs via W13. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	GitHub code security documentation `https://docs.github.com/en/code-security`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a sanitized public repository with report, sample evidence, README, scope statement, limitations and lessons learned; remove IPs/secrets/personal data. **2.** Standard (~2 h): Create a sanitized public repository with report, sample evidence, README, scope statement, limitations and lessons learned; remove IPs/secrets/personal data. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a sanitized public repository with report, sample evidence, README, scope statement, limitations and lessons learned; remove IPs/secrets/personal data. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	published PRJ-10 repository; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which part of the project demonstrates independent problem-solving rather than tool output? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Portfolio checklist passes and no sensitive evidence is published Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Pro Git Chapters 2-3 and GitHub security docs via W13"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Python for Everybody; write a five-line correction; retest next morning with a new 10-minute problem.

D193 · M07W4D4 · Certification and specialization decision point

Phase: Academic month · **Optional date:** 2027-05-07 · **Domain resources:** A22 / E01

1. Day / sequence	Global Day 193 of 365; calendar-free M07W4D4; optional date 2027-05-07.
2. Exact topic	Certification and specialization decision point
3. Exact subtopics	eJPT, OSCP, Security+, CCST and free alternatives; skills demonstrated versus credentials
4. Learning objective	Decide whether a paid pentesting certification is appropriate after Year 1
5. Primary lecture / reading + direct URL	INE eJPT official certification page `https://ine.com/security/certifications/ejpt-certification` **Type:** Official certification page · **Access:** Paid; official page states an INE subscription and exam voucher are needed; checkout lists voucher/bundle prices
6. Exact section / lesson locator	INE eJPT official certification page; A21 OffSec PEN-200 OSCP+ page; E01 free NIST methodology. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Compare three certifications with official objectives, costs, prerequisites and free alternatives; write a budget-aware recommendation for Month 12 and Year 2. **2.** Standard (~2 h): Compare three certifications with official objectives, costs, prerequisites and free alternatives; write a budget-aware recommendation for Month 12 and Year 2. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Compare three certifications with official objectives, costs, prerequisites and free alternatives; write a budget-aware recommendation for Month 12 and Year 2. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	pentest-cert-decision.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What skill would the exam validate that your capstone does not? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Current official facts and prices are cited with verification date; no purchase is treated as mandatory Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "INE eJPT official certification page; A21 OffSec PEN-200 OSCP+ page; E01 free NIST methodology"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST SP 800-115; write a five-line correction; retest next morning with a new 10-minute problem.

D194 · M07W4D5 · Month 7 practical examination and mastery gate

Phase: Academic month · **Optional date:** 2027-05-08 · **Domain resources:** E01 / W06

1. Day / sequence	Global Day 194 of 365; calendar-free M07W4D5; optional date 2027-05-08.
2. Exact topic	Month 7 practical examination and mastery gate
3. Exact subtopics	Authorization, scope, asset inventory, discovery, validation, risk, evidence, remediation, retest, reporting and disclosure
4. Learning objective	Demonstrate ethical testing competence in a time-boxed authorized assessment
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115 full workflow. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	OWASP Web Security Testing Guide `https://owasp.org/www-project-web-security-testing-guide/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete a 150-minute practical on a new isolated lab with an unseen scope document and two synthetic vulnerabilities; produce evidence and a report. **2.** Standard (~2 h): Complete a 150-minute practical on a new isolated lab with an unseen scope document and two synthetic vulnerabilities; produce evidence and a report. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete a 150-minute practical on a new isolated lab with an unseen scope document and two synthetic vulnerabilities; produce evidence and a report. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M7-assessment.pdf and scorecard; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which action would you refuse to perform even if the client requested it informally? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100, safety at least 9/10 and no scope violation Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115 full workflow"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D195 · M07W4D6 · Monthly review and gap repairs

Phase: Academic month · **Optional date:** 2027-05-09 · **Domain resources:** E01 / C01

1. Day / sequence	Global Day 195 of 365; calendar-free M07W4D6; optional date 2027-05-09.
2. Exact topic	Monthly review and gap repairs
3. Exact subtopics	Scope errors, scan interpretation, validation logic, CVSS misuse, evidence quality and report clarity
4. Learning objective	Repair Month 7 gaps and prepare blue-team log analysis
5. Primary lecture / reading + direct URL	NIST SP 800-115 `https://csrc.nist.gov/pubs/sp/800/115/final` **Type:** Official testing guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-115 and W06 WSTG reporting sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Professor Messer SY0-701 Security+ Course Index `https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Rework failed assessment items, rewrite one weak remediation, add ten flashcards, and map each Month 8 topic to skills from Months 1-7. **2.** Standard (~2 h): Rework failed assessment items, rewrite one weak remediation, add ten flashcards, and map each Month 8 topic to skills from Months 1-7. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Rework failed assessment items, rewrite one weak remediation, add ten flashcards, and map each Month 8 topic to skills from Months 1-7. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M7-review.md and retest score; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which offensive validation skill will be most useful for detection engineering? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Retest score at least 80 percent and no unresolved safety gaps Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-115 and W06 WSTG reporting sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup OWASP Web Security Testing Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D196 · M07W4D7 · Spaced revision, recovery and Month 8 preview

Phase: Academic month · **Optional date:** 2027-05-10 · **Domain resources:** E05 / B02 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 196 of 365; calendar-free M07W4D7; optional date 2027-05-10.
2. Exact topic	Spaced revision, recovery and Month 8 preview
3. Exact subtopics	Ethics, RoE, evidence, validation, risk and reporting; active recall and lab cleanup
4. Learning objective	Preserve ethical-testing knowledge and shift to defensive investigation mindset
5. Primary lecture / reading + direct URL	HackerOne Disclosure Guidelines `https://www.hackerone.com/disclosure-guidelines` **Type:** Responsible disclosure guidance · **Access:** Free
6. Exact section / lesson locator	HackerOne Disclosure Guidelines and E06 FIRST CVSS calculator. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, destroy/reset assessment VMs from clean snapshots, organize evidence backups, and preview KQL basics — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, destroy/reset assessment VMs from clean snapshots, organize evidence backups, and preview KQL basics — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, destroy/reset assessment VMs from clean snapshots, organize evidence backups, and preview KQL basics — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M7-consolidation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: How does an attacker's evidence chain become a defender's detection hypothesis? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Lab is clean, evidence is archived, and the explanation is coherent Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "HackerOne Disclosure Guidelines and E06 FIRST CVSS calculator"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup FIRST CVSS specification; write a five-line correction; retest next morning with a new 10-minute problem.

Month 08 — Blue team, SOC, logs, SIEM and incident response

Days D197-D224. Each day has the same 13-field structure. Use the Core, Standard or Intensive track; the learning objective does not change. Day 7 of each week is lighter by design.

Week	Daily topics
Week 1	D1: SOC roles, workflows and alert lifecycle D2: SIEM concepts and log pipeline D3: Windows and Linux security logs D4: Alert triage and hypotheses D5: Indicators of compromise and confidence D6: MITRE ATT&CK and detection coverage D7: Weekly blue-team foundations review
Week 2	D1: Incident response lifecycle and evidence handling D2: KQL fundamentals for security logs D3: Detection rule anatomy and Sigma D4: Detection engineering lifecycle D5: Endpoint detection and response concepts D6: Weekly detection engineering review D7: Threat hunting methodology
Week 3	D1: Threat intelligence and advisory reading D2: False-positive analysis and tuning D3: Digital forensics fundamentals and evidence integrity D4: Weekly hunting, DFIR and tuning review D5: Incident report writing and stakeholder communication D6: SIEM alert investigation capstone: data preparation D7: SIEM alert investigation capstone: investigation
Week 4	D1: SIEM alert investigation capstone: response and lessons D2: Blue-team portfolio publication D3: Blue-team specialization taster and decision evidence D4: Month 8 practical examination and milestone gate D5: Monthly review and gap repairs D6: Network forensics and malware-traffic safety D7: Spaced revision, recovery and Month 9 preview

> **Gate:** score the Month 8 assessment using the 100-point rubric in Volume 6. If score <70 or safety <9/10, follow the six-step repair protocol before advancing.

Month 08 · Week 1 · daily cards

D197 · M08W1D1 · SOC roles, workflows and alert lifecycle

Phase: Academic month · **Optional date:** 2027-05-11 · **Domain resources:** B01 / C20

1. Day / sequence	Global Day 197 of 365; calendar-free M08W1D1; optional date 2027-05-11.
2. Exact topic	SOC roles, workflows and alert lifecycle
3. Exact subtopics	Tier 1/2/3, monitoring, intake, triage, escalation, investigation, containment recommendation, closure and handoff
4. Learning objective	Explain an alert's path from telemetry to decision and evidence
5. Primary lecture / reading + direct URL	Microsoft Sentinel documentation `https://learn.microsoft.com/en-us/azure/sentinel/` **Type:** Official documentation · **Access:** Docs free; Azure/Sentinel usage may incur costs
6. Exact section / lesson locator	Microsoft Sentinel documentation, overview, incidents and SOC workflow sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST NICE Workforce Framework `https://www.nist.gov/itl/applied-cybersecurity/nice`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Draw a SOC workflow for a synthetic failed-login spike and label decision points, data sources and handoff notes. **2.** Standard (~2 h): Draw a SOC workflow for a synthetic failed-login spike and label decision points, data sources and handoff notes. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Draw a SOC workflow for a synthetic failed-login spike and label decision points, data sources and handoff notes. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	soc-workflow.svg; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which step is missing if alerts are closed without a documented rationale? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Workflow includes feedback, false-positive learning and escalation criteria Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Microsoft Sentinel documentation, overview, incidents and SOC workflow sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Kusto Query Language overview; write a five-line correction; retest next morning with a new 10-minute problem.

D198 · M08W1D2 · SIEM concepts and log pipeline

Phase: Academic month · **Optional date:** 2027-05-12 · **Domain resources:** B01 / B02

1. Day / sequence	Global Day 198 of 365; calendar-free M08W1D2; optional date 2027-05-12.
2. Exact topic	SIEM concepts and log pipeline
3. Exact subtopics	Collection, parsing, normalization, enrichment, indexing, retention, correlation, dashboards, case management and cost drivers
4. Learning objective	Design a log pipeline for a small lab with synthetic data
5. Primary lecture / reading + direct URL	Microsoft Sentinel documentation `https://learn.microsoft.com/en-us/azure/sentinel/` **Type:** Official documentation · **Access:** Docs free; Azure/Sentinel usage may incur costs
6. Exact section / lesson locator	Microsoft Sentinel documentation, data connectors, workspace, analytics and hunting sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Ingest a small synthetic CSV/JSON log set into a local notebook or free-tier lab only if budgets are configured; otherwise simulate with SQLite/KQL-style queries. **2.** Standard (~2 h): Ingest a small synthetic CSV/JSON log set into a local notebook or free-tier lab only if budgets are configured; otherwise simulate with SQLite/KQL-style queries. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Ingest a small synthetic CSV/JSON log set into a local notebook or free-tier lab only if budgets are configured; otherwise simulate with SQLite/KQL-style queries. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	log-pipeline-design.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does normalization matter more than collecting raw logs without schema? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Design includes parsing, timestamp/time zone, retention and privacy controls Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Microsoft Sentinel documentation, data connectors, workspace, analytics and hunting sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Kusto Query Language overview; write a five-line correction; retest next morning with a new 10-minute problem.

D199 · M08W1D3 · Windows and Linux security logs

Phase: Academic month · **Optional date:** 2027-05-13 · **Domain resources:** L09 / B05

1. Day / sequence	Global Day 199 of 365; calendar-free M08W1D3; optional date 2027-05-13.
2. Exact topic	Windows and Linux security logs
3. Exact subtopics	Security/System/Application channels, Sysmon, auth.log, journald, process creation, logon, service, network and file events
4. Learning objective	Map an adversary behaviour to the log fields that reveal it
5. Primary lecture / reading + direct URL	Windows Event Log documentation `https://learn.microsoft.com/en-us/windows/win32/wes/windows-event-log` **Type:** Official reference · **Access:** Free
6. Exact section / lesson locator	Windows Event Log documentation and L05 systemd/journald manual. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SBousseaden EVTX-ATTACK-SAMPLES `https://github.com/sbousseaden/EVTX-ATTACK-SAMPLES`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a cross-platform log-source matrix for process creation, authentication, network connection, service change and file access. **2.** Standard (~2 h): Create a cross-platform log-source matrix for process creation, authentication, network connection, service change and file access. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a cross-platform log-source matrix for process creation, authentication, network connection, service change and file access. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	log-source-matrix.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which behaviour has the weakest visibility in your current lab and why? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Matrix includes event IDs/field names and explicit visibility gaps Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Windows Event Log documentation and L05 systemd/ journald manual"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Sysmon documentation and download; write a five-line correction; retest next morning with a new 10-minute problem.

D200 · M08W1D4 · Alert triage and hypotheses

Phase: Academic month · **Optional date:** 2027-05-14 · **Domain resources:** B15 / C18

1. Day / sequence	Global Day 200 of 365; calendar-free M08W1D4; optional date 2027-05-14.
2. Exact topic	Alert triage and hypotheses
3. Exact subtopics	Alert context, affected assets, severity, confidence, prevalence, first/last seen, known baseline and competing hypotheses
4. Learning objective	Triage a synthetic alert without jumping to a conclusion
5. Primary lecture / reading + direct URL	Microsoft SC-200 certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-operations-analyst/` **Type:** Official certification page · **Access:** Free learning content; exam price region-based
6. Exact section / lesson locator	Microsoft SC-200 certification page and official study guide, threat response/hunting sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: For one synthetic alert, write three competing hypotheses and the exact query or evidence that would discriminate among them. **2.** Standard (~2 h): For one synthetic alert, write three competing hypotheses and the exact query or evidence that would discriminate among them. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): For one synthetic alert, write three competing hypotheses and the exact query or evidence that would discriminate among them. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	alert-triage.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: What observation would prove the alert is a false positive? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Each hypothesis has a discriminating test and outcome criteria Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Microsoft SC-200 certification page and official study guide, threat response/hunting sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Microsoft Sentinel documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D201 · M08W1D5 · Indicators of compromise and confidence

Phase: Academic month · **Optional date:** 2027-05-15 · **Domain resources:** C18 / B17

1. Day / sequence	Global Day 201 of 365; calendar-free M08W1D5; optional date 2027-05-15.
2. Exact topic	Indicators of compromise and confidence
3. Exact subtopics	Atomic, computed and behavioural indicators; hashes, domains, IPs, user agents, mutexes, TTPs; confidence and expiration
4. Learning objective	Explain why an IOC is not equivalent to an incident
5. Primary lecture / reading + direct URL	MITRE ATT&CK `https://attack.mitre.org/` **Type:** Knowledge base · **Access:** Free
6. Exact section / lesson locator	MITRE ATT&CK, tactics/techniques/data sources and detection notes. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CISA cybersecurity advisories `https://www.cisa.gov/news-events/cybersecurity-advisories`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Build an IOC table for a synthetic scenario with type, source, confidence, expiration, false-positive risk and recommended action. **2.** Standard (~2 h): Build an IOC table for a synthetic scenario with type, source, confidence, expiration, false-positive risk and recommended action. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Build an IOC table for a synthetic scenario with type, source, confidence, expiration, false-positive risk and recommended action. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	ioc-table.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is a behavioural TTP often more durable than an IP address? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Table includes decay/expiration and no claim that an IOC alone confirms compromise Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "MITRE ATT&CK, tactics/techniques/data sources and detection notes"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE D3FEND; write a five-line correction; retest next morning with a new 10-minute problem.

D202 · M08W1D6 · MITRE ATT&CK and detection coverage

Phase: Academic month · **Optional date:** 2027-05-16 · **Domain resources:** C18 / C19

1. Day / sequence	Global Day 202 of 365; calendar-free M08W1D6; optional date 2027-05-16.
2. Exact topic	MITRE ATT&CK and detection coverage
3. Exact subtopics	Tactics, techniques, sub-techniques, procedures, data sources, mitigations, Navigator and coverage caveats
4. Learning objective	Map one synthetic incident to techniques and required telemetry
5. Primary lecture / reading + direct URL	MITRE ATT&CK `https://attack.mitre.org/` **Type:** Knowledge base · **Access:** Free
6. Exact section / lesson locator	MITRE ATT&CK, Enterprise matrix and technique pages. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE D3FEND `https://d3fend.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create an ATT&CK Navigator-style layer for five techniques in your own lab; mark data required and current detection confidence. **2.** Standard (~2 h): Create an ATT&CK Navigator-style layer for five techniques in your own lab; mark data required and current detection confidence. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create an ATT&CK Navigator-style layer for five techniques in your own lab; mark data required and current detection confidence. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	attack-layer.json and explanation; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why does a claimed technique coverage not prove a useful detection? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Layer is correctly formatted and each technique has explicit data-source evidence Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "MITRE ATT&CK, Enterprise matrix and technique pages"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE D3FEND; write a five-line correction; retest next morning with a new 10-minute problem.

D203 · M08W1D7 · Weekly blue-team foundations review

Phase: Academic month · **Optional date:** 2027-05-17 · **Domain resources:** B02 / B03 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 203 of 365; calendar-free M08W1D7; optional date 2027-05-17.
2. Exact topic	Weekly blue-team foundations review
3. Exact subtopics	SOC workflow, SIEM pipeline, logs, triage, IOCs and ATT&CK; active recall and scenario
4. Learning objective	Demonstrate Month 8 Week 1 competence with an unfamiliar synthetic alert
5. Primary lecture / reading + direct URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric` **Type:** Official language docs · **Access:** Free
6. Exact section / lesson locator	KQL overview, where/tabular operators and summarize sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SigmaHQ `https://sigmahq.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute scenario: normalize logs, query an alert, map ATT&CK and recommend escalation or closure with confidence — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute scenario: normalize logs, query an alert, map ATT&CK and recommend escalation or closure with confidence — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Complete a 60-minute scenario: normalize logs, query an alert, map ATT&CK and recommend escalation or closure with confidence — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M8W1-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which evidence would change your escalation decision? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and all conclusions cite specific fields Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "KQL overview, where/tabular operators and summarize sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

Month 08 · Week 2 · daily cards

D204 · M08W2D1 · Incident response lifecycle and evidence handling

Phase: Academic month · **Optional date:** 2027-05-18 · **Domain resources:** C07 / B11

1. Day / sequence	Global Day 204 of 365; calendar-free M08W2D1; optional date 2027-05-18.
2. Exact topic	Incident response lifecycle and evidence handling
3. Exact subtopics	Preparation, detection, analysis, containment, eradication, recovery, lessons learned, legal hold and chain of custody
4. Learning objective	Build an IR runbook for a synthetic credential-theft incident
5. Primary lecture / reading + direct URL	NIST SP 800-61 Revision 3 `https://csrc.nist.gov/pubs/sp/800/61/r3/final` **Type:** Official guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-61r3, incident response life cycle and CSF alignment. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Autopsy documentation `https://www.autopsy.com/support/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write a runbook with roles, decision tree, evidence preservation, containment options, communication and recovery verification. **2.** Standard (~2 h): Write a runbook with roles, decision tree, evidence preservation, containment options, communication and recovery verification. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write a runbook with roles, decision tree, evidence preservation, containment options, communication and recovery verification. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	ir-runbook.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which containment action could destroy volatile evidence? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Runbook balances containment with evidence preservation and includes rollback Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-61r3, incident response life cycle and CSF alignment"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D205 · M08W2D2 · KQL fundamentals for security logs

Phase: Academic month · **Optional date:** 2027-05-19 · **Domain resources:** B02 / A23

1. Day / sequence	Global Day 205 of 365; calendar-free M08W2D2; optional date 2027-05-19.
2. Exact topic	KQL fundamentals for security logs
3. Exact subtopics	Tables, where, project, extend, summarize, count, join, let, time filters, dynamic fields and render basics
4. Learning objective	Query synthetic security events to answer investigative questions
5. Primary lecture / reading + direct URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric` **Type:** Official language docs · **Access:** Free
6. Exact section / lesson locator	KQL overview and tutorial, learn common operators sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	KQL Essentials official Azure Data Explorer playlist `https://www.youtube.com/playlist?list=PLKHIhZJiQ5AkOMEC54mQQcAkfg4UXT8uK`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write ten KQL-style queries against a free sample dataset or a local equivalent; explain each operator and output. **2.** Standard (~2 h): Write ten KQL-style queries against a free sample dataset or a local equivalent; explain each operator and output. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write ten KQL-style queries against a free sample dataset or a local equivalent; explain each operator and output. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	kql-queries.kql and results; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can a join on a high-cardinality field create misleading or expensive results? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	All queries are syntactically valid in the chosen environment and results are interpreted Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "KQL overview and tutorial, learn common operators sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D206 · M08W2D3 · Detection rule anatomy and Sigma

Phase: Academic month · **Optional date:** 2027-05-20 · **Domain resources:** B04 / B03

1. Day / sequence	Global Day 206 of 365; calendar-free M08W2D3; optional date 2027-05-20.
2. Exact topic	Detection rule anatomy and Sigma
3. Exact subtopics	logsource, detection, selection, condition, falsepositives, level, tags, metadata and conversion to SIEM queries
4. Learning objective	Write a readable, vendor-neutral detection rule
5. Primary lecture / reading + direct URL	Sigma rule creation guide `https://sigmahq.io/docs/guide/getting-started.html` **Type:** Official rule reference · **Access:** Free
6. Exact section / lesson locator	Sigma getting-started documentation, rule structure and conversion sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SigmaHQ `https://sigmahq.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Author one original Sigma rule for a benign lab behaviour and convert it to a local query; include true/false-positive test cases. **2.** Standard (~2 h): Author one original Sigma rule for a benign lab behaviour and convert it to a local query; include true/false-positive test cases. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Author one original Sigma rule for a benign lab behaviour and convert it to a local query; include true/false-positive test cases. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	detection-rule.yml and test-data.json; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which field in your rule is most likely to cause a false positive in a real environment? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Rule validates, converts, and test results are documented Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Sigma getting-started documentation, rule structure and conversion sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D207 · M08W2D4 · Detection engineering lifecycle

Phase: Academic month · **Optional date:** 2027-05-21 · **Domain resources:** B14 / B03

1. Day / sequence	Global Day 207 of 365; calendar-free M08W2D4; optional date 2027-05-21.
2. Exact topic	Detection engineering lifecycle
3. Exact subtopics	Hypothesis, data requirements, rule design, backtesting, tuning, deployment, version control, measurement and retirement
4. Learning objective	Treat detections as software with tests and feedback loops
5. Primary lecture / reading + direct URL	Elastic detection rules documentation `https://www.elastic.co/guide/en/security/current/detection-engine-overview.html` **Type:** Official docs / open-source rules · **Access:** Free docs/open-source rules; Elastic Stack may have paid features
6. Exact section / lesson locator	Elastic detection rules documentation, rule types, exceptions and alerting. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SigmaHQ `https://sigmahq.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a detection-as-code repository with one rule, unit tests, sample data, README and version history. **2.** Standard (~2 h): Create a detection-as-code repository with one rule, unit tests, sample data, README and version history. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a detection-as-code repository with one rule, unit tests, sample data, README and version history. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-12 repository draft; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: How would you measure the detection's value beyond alert count? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Repository includes tests, owners, tuning notes and false-positive metrics Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Elastic detection rules documentation, rule types, exceptions and alerting"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D208 · M08W2D5 · Endpoint detection and response concepts

Phase: Academic month · **Optional date:** 2027-05-22 · **Domain resources:** B15 / C18

1. Day / sequence	Global Day 208 of 365; calendar-free M08W2D5; optional date 2027-05-22.
2. Exact topic	Endpoint detection and response concepts
3. Exact subtopics	EDR telemetry, process trees, behavioural detection, isolation, response actions, tamper protection and privacy
4. Learning objective	Explain EDR's strengths and blind spots without relying on vendor marketing
5. Primary lecture / reading + direct URL	Microsoft SC-200 certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-operations-analyst/` **Type:** Official certification page · **Access:** Free learning content; exam price region-based
6. Exact section / lesson locator	Microsoft SC-200 study guide and B01 Defender/Sentinel documentation. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Compare EDR telemetry with Windows Security and Sysmon logs for one synthetic process chain; list two blind spots. **2.** Standard (~2 h): Compare EDR telemetry with Windows Security and Sysmon logs for one synthetic process chain; list two blind spots. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Compare EDR telemetry with Windows Security and Sysmon logs for one synthetic process chain; list two blind spots. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	edr-notes.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why can endpoint isolation be a containment control and a business-risk decision at the same time? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Comparison is grounded in data fields and includes privacy/operational limits Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Microsoft SC-200 study guide and B01 Defender/Sentinel documentation"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Microsoft Sentinel documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D209 · M08W2D6 · Weekly detection engineering review

Phase: Academic month · **Optional date:** 2027-05-23 · **Domain resources:** B04 / C18

1. Day / sequence	Global Day 209 of 365; calendar-free M08W2D6; optional date 2027-05-23.
2. Exact topic	Weekly detection engineering review
3. Exact subtopics	IR lifecycle, KQL, Sigma, detection-as-code, EDR and ATT&CK; active recall and code review
4. Learning objective	Demonstrate Month 8 Week 2 competence through a detection challenge
5. Primary lecture / reading + direct URL	Sigma rule creation guide `https://sigmahq.io/docs/guide/getting-started.html` **Type:** Official rule reference · **Access:** Free
6. Exact section / lesson locator	Sigma getting-started rule conversion examples and B14 detection rule repository. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Receive one synthetic behaviour, write a detection hypothesis, create a rule, test true/false positives and explain residual risk. **2.** Standard (~2 h): Receive one synthetic behaviour, write a detection hypothesis, create a rule, test true/false positives and explain residual risk. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Receive one synthetic behaviour, write a detection hypothesis, create a rule, test true/false positives and explain residual risk. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M8W2-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which test data would make your rule fail silently? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and the rule has both passing and failing test cases Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Sigma getting-started rule conversion examples and B14 detection rule repository"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D210 · M08W2D7 · Threat hunting methodology

Phase: Academic month · **Optional date:** 2027-05-24 · **Domain resources:** B15 / C18 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 210 of 365; calendar-free M08W2D7; optional date 2027-05-24.
2. Exact topic	Threat hunting methodology
3. Exact subtopics	Hypothesis-driven hunting, baseline, anomaly, known-behhaviour search, data quality, pivoting and documenting negative results
4. Learning objective	Design a hunt from a technique rather than a tool
5. Primary lecture / reading + direct URL	Microsoft SC-200 certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-operations-analyst/` **Type:** Official certification page · **Access:** Free learning content; exam price region-based
6. Exact section / lesson locator	Microsoft SC-200 study guide, threat hunting section and B01 Sentinel hunting docs. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Choose one ATT&CK technique, list required fields, write three hunt queries and define what a negative result means — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Choose one ATT&CK technique, list required fields, write three hunt queries and define what a negative result means — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Choose one ATT&CK technique, list required fields, write three hunt queries and define what a negative result means — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	hunt-plan.md and query output; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Why is a negative hunt result only meaningful if data coverage is verified? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Hunt plan includes data-quality checks and explicit limitations Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Microsoft SC-200 study guide, threat hunting section and B01 Sentinel hunting docs"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Microsoft Sentinel documentation; write a five-line correction; retest next morning with a new 10-minute problem.

Month 08 · Week 3 · daily cards

D211 · M08W3D1 · Threat intelligence and advisory reading

Phase: Academic month · **Optional date:** 2027-05-25 · **Domain resources:** B17 / C18

1. Day / sequence	Global Day 211 of 365; calendar-free M08W3D1; optional date 2027-05-25.
2. Exact topic	Threat intelligence and advisory reading
3. Exact subtopics	Strategic/operational/tactical/technical intelligence, source reliability, confidence, indicator decay, STIX/TAXII concepts and analytic bias
4. Learning objective	Convert an advisory into a prioritized local detection hypothesis
5. Primary lecture / reading + direct URL	CISA cybersecurity advisories `https://www.cisa.gov/news-events/cybersecurity-advisories` **Type:** Official advisories · **Access:** Free
6. Exact section / lesson locator	CISA cybersecurity advisories and B18 KEV catalog; choose one current advisory. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Read one official advisory, extract two TTPs and two mitigations, map to ATT&CK and write one detection hypothesis. **2.** Standard (~2 h): Read one official advisory, extract two TTPs and two mitigations, map to ATT&CK and write one detection hypothesis. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Read one official advisory, extract two TTPs and two mitigations, map to ATT&CK and write one detection hypothesis. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	advisory-analysis.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which part of the advisory is an observation and which is an assessment? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Sources are cited, confidence is stated, and no IOC is treated as proof Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CISA cybersecurity advisories and B18 KEV catalog; choose one current advisory"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE ATT&CK; write a five-line correction; retest next morning with a new 10-minute problem.

D212 · M08W3D2 · False-positive analysis and tuning

Phase: Academic month · **Optional date:** 2027-05-26 · **Domain resources:** B14 / B03

1. Day / sequence	Global Day 212 of 365; calendar-free M08W3D2; optional date 2027-05-26.
2. Exact topic	False-positive analysis and tuning
3. Exact subtopics	Benign triggers, prevalence, suppression, exceptions, risk-based scoring, rule decay and feedback from analysts
4. Learning objective	Tune a noisy rule without hiding true positives
5. Primary lecture / reading + direct URL	Elastic detection rules documentation `https://www.elastic.co/guide/en/security/current/detection-engine-overview.html` **Type:** Official docs / open-source rules · **Access:** Free docs/open-source rules; Elastic Stack may have paid features
6. Exact section / lesson locator	Elastic detection rules documentation, exceptions and alert investigation. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SigmaHQ `https://sigmahq.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a synthetic noisy dataset, run a rule, classify ten alerts, tune with a narrow exception and document what was excluded. **2.** Standard (~2 h): Create a synthetic noisy dataset, run a rule, classify ten alerts, tune with a narrow exception and document what was excluded. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a synthetic noisy dataset, run a rule, classify ten alerts, tune with a narrow exception and document what was excluded. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	false-positive-report.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why is blanket suppression more dangerous than a narrow, reviewed exception? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Tuning reduces benign alerts and preserves all assigned malicious test cases Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Elastic detection rules documentation, exceptions and alert investigation"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D213 · M08W3D3 · Digital forensics fundamentals and evidence integrity

Phase: Academic month · **Optional date:** 2027-05-27 · **Domain resources:** B11 / C07

1. Day / sequence	Global Day 213 of 365; calendar-free M08W3D3; optional date 2027-05-27.
2. Exact topic	Digital forensics fundamentals and evidence integrity
3. Exact subtopics	Order of volatility, acquisition, write blocking, hashing, timelines, file system artifacts, memory concepts and legal authorization
4. Learning objective	Explain how to preserve evidence before analysis
5. Primary lecture / reading + direct URL	Autopsy documentation `https://www.autopsy.com/support/` **Type:** Official tool docs · **Access:** Free/open-source
6. Exact section / lesson locator	Autopsy documentation, case creation, disk images and reports. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	NIST SP 800-61 Revision 3 `https://csrc.nist.gov/pubs/sp/800/61/r3/final`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Create a benign test disk image or use a provided synthetic image, hash it, acquire it, and build a simple timeline without modifying the original. **2.** Standard (~2 h): Create a benign test disk image or use a provided synthetic image, hash it, acquire it, and build a simple timeline without modifying the original. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Create a benign test disk image or use a provided synthetic image, hash it, acquire it, and build a simple timeline without modifying the original. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	forensic-case.md and hash manifest; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why must analysis happen on a copy rather than the original evidence? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Hashes match, chain of custody is documented and original remains unchanged Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Autopsy documentation, case creation, disk images and reports"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SANS SIFT Workstation; write a five-line correction; retest next morning with a new 10-minute problem.

D214 · M08W3D4 · Weekly hunting, DFIR and tuning review

Phase: Academic month · **Optional date:** 2027-05-28 · **Domain resources:** B17 / B03

1. Day / sequence	Global Day 214 of 365; calendar-free M08W3D4; optional date 2027-05-28.
2. Exact topic	Weekly hunting, DFIR and tuning review
3. Exact subtopics	Hypothesis hunting, threat intel, false positives, forensics and evidence integrity; active recall
4. Learning objective	Demonstrate Month 8 Week 3 competence with a mixed incident pack
5. Primary lecture / reading + direct URL	CISA cybersecurity advisories `https://www.cisa.gov/news-events/cybersecurity-advisories` **Type:** Official advisories · **Access:** Free
6. Exact section / lesson locator	CISA advisories and B11 Autopsy documentation case workflow. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SigmaHQ `https://sigmahq.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Analyze a synthetic incident pack containing logs, one IOC and one disk artifact; decide true/false positive and document evidence limits. **2.** Standard (~2 h): Analyze a synthetic incident pack containing logs, one IOC and one disk artifact; decide true/false positive and document evidence limits. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Analyze a synthetic incident pack containing logs, one IOC and one disk artifact; decide true/false positive and document evidence limits. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M8W3-practical.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which artifact corroborates the log timeline and which only suggests a possibility? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100 and evidence integrity rules are followed Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "CISA advisories and B11 Autopsy documentation case workflow"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup MITRE ATT&CK; write a five-line correction; retest next morning with a new 10-minute problem.

D215 · M08W3D5 · Incident report writing and stakeholder communication

Phase: Academic month · **Optional date:** 2027-05-29 · **Domain resources:** C07 / B17

1. Day / sequence	Global Day 215 of 365; calendar-free M08W3D5; optional date 2027-05-29.
2. Exact topic	Incident report writing and stakeholder communication
3. Exact subtopics	Executive summary, timeline, scope, impact, root cause, evidence, confidence, containment, recovery, recommendations and lessons learned
4. Learning objective	Write an incident report that separates confirmed facts from hypotheses
5. Primary lecture / reading + direct URL	NIST SP 800-61 Revision 3 `https://csrc.nist.gov/pubs/sp/800/61/r3/final` **Type:** Official guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-61r3, improvement and communications sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	CISA cybersecurity advisories `https://www.cisa.gov/news-events/cybersecurity-advisories`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write a six-page incident report for a synthetic credential-theft case with timestamps, evidence references and uncertainty labels. **2.** Standard (~2 h): Write a six-page incident report for a synthetic credential-theft case with timestamps, evidence references and uncertainty labels. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write a six-page incident report for a synthetic credential-theft case with timestamps, evidence references and uncertainty labels. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-11 incident-report.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which sentence would be inappropriate because it overstates the evidence? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Report scores at least 70/100 and all claims have confidence labels Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-61r3, improvement and communications sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D216 · M08W3D6 · SIEM alert investigation capstone: data preparation

Phase: Academic month · **Optional date:** 2027-05-30 · **Domain resources:** B02 / B05

1. Day / sequence	Global Day 216 of 365; calendar-free M08W3D6; optional date 2027-05-30.
2. Exact topic	SIEM alert investigation capstone: data preparation
3. Exact subtopics	Synthetic log generation, normalization, time synchronization, entity mapping and case metadata
4. Learning objective	Build a safe dataset that can reproduce an alert investigation
5. Primary lecture / reading + direct URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric` **Type:** Official language docs · **Access:** Free
6. Exact section / lesson locator	KQL overview and B01 Sentinel data collection overview. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SBousseaden EVTX-ATTACK-SAMPLES `https://github.com/sbousseaden/EVTX-ATTACK-SAMPLES`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Generate or download synthetic Windows/ Linux logs, normalize fields, document schema and hash all input files. **2.** Standard (~2 h): Generate or download synthetic Windows/Linux logs, normalize fields, document schema and hash all input files. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Generate or download synthetic Windows/Linux logs, normalize fields, document schema and hash all input files. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-11/data/ with README and manifest; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Why must all event times use one time zone before correlation? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Dataset is reproducible, synthetic and schema-documented Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "KQL overview and B01 Sentinel data collection overview"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D217 · M08W3D7 · SIEM alert investigation capstone: investigation

Phase: Academic month · **Optional date:** 2027-05-31 · **Domain resources:** B02 / B15 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 217 of 365; calendar-free M08W3D7; optional date 2027-05-31.
2. Exact topic	SIEM alert investigation capstone: investigation
3. Exact subtopics	Query, pivot, correlate, enrich, assess scope, dismiss benign explanations and build a timeline
4. Learning objective	Investigate an alert end-to-end using only authorized synthetic data
5. Primary lecture / reading + direct URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric` **Type:** Official language docs · **Access:** Free
6. Exact section / lesson locator	KQL operators, joins, summarize and let statements. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Microsoft SC-200 certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-operations-analyst/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Run at least eight investigative queries, pivot across user/host/IP, produce a timeline and state what is known, likely and unknown — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Run at least eight investigative queries, pivot across user/host/IP, produce a timeline and state what is known, likely and unknown — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Run at least eight investigative queries, pivot across user/host/IP, produce a timeline and state what is known, likely and unknown — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-11/investigation.md and query log; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which alternative explanation remains plausible after your investigation? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Timeline is evidence-backed and uncertainty is explicit Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "KQL operators, joins, summarize and let statements"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

Month 08 · Week 4 · daily cards

D218 · M08W4D1 · SIEM alert investigation capstone: response and lessons

Phase: Academic month · **Optional date:** 2027-06-01 · **Domain resources:** C07 / B03

1. Day / sequence	Global Day 218 of 365; calendar-free M08W4D1; optional date 2027-06-01.
2. Exact topic	SIEM alert investigation capstone: response and lessons
3. Exact subtopics	Containment recommendation, eradication, recovery validation, detection gap, rule improvement and stakeholder summary
4. Learning objective	Convert investigation findings into measurable improvements
5. Primary lecture / reading + direct URL	NIST SP 800-61 Revision 3 `https://csrc.nist.gov/pubs/sp/800/61/r3/final` **Type:** Official guidance · **Access:** Free
6. Exact section / lesson locator	NIST SP 800-61r3 post-incident activity and lessons learned. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	SigmaHQ `https://sigmahq.io/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Write a response plan, improve one detection rule, add three regression tests and produce a one-page executive summary. **2.** Standard (~2 h): Write a response plan, improve one detection rule, add three regression tests and produce a one-page executive summary. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Write a response plan, improve one detection rule, add three regression tests and produce a one-page executive summary. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	PRJ-11/response.md and updated rule; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: How would you prove recovery rather than assume it? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Response plan includes validation and the new rule passes assigned tests Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST SP 800-61r3 post-incident activity and lessons learned"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D219 · M08W4D2 · Blue-team portfolio publication

Phase: Academic month · **Optional date:** 2027-06-02 · **Domain resources:** F09 / B01

1. Day / sequence	Global Day 219 of 365; calendar-free M08W4D2; optional date 2027-06-02.
2. Exact topic	Blue-team portfolio publication
3. Exact subtopics	Sanitization, architecture, dataset provenance, queries, report, detection rule, test results and limitations
4. Learning objective	Publish a professional defensive case study
5. Primary lecture / reading + direct URL	Pro Git, 2nd Edition `https://git-scm.com/book/en/v2` **Type:** Free book / official reference · **Access:** Free
6. Exact section / lesson locator	Pro Git Chapters 2-3 and W13 GitHub security docs for public repository hygiene. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Microsoft Sentinel documentation `https://learn.microsoft.com/en-us/azure/sentinel/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Finalize PRJ-11 and PRJ-12 with READMEs, screenshots, query files, synthetic data, threat model and limitations. **2.** Standard (~2 h): Finalize PRJ-11 and PRJ-12 with READMEs, screenshots, query files, synthetic data, threat model and limitations. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Finalize PRJ-11 and PRJ-12 with READMEs, screenshots, query files, synthetic data, threat model and limitations. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	published blue-team repositories; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which file proves the detection was tested on both true and false positives? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Portfolio checklist passes and no sensitive log data or credentials are public Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Pro Git Chapters 2-3 and W13 GitHub security docs for public repository hygiene"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Python for Everybody; write a five-line correction; retest next morning with a new 10-minute problem.

D220 · M08W4D3 · Blue-team specialization taster and decision evidence

Phase: Academic month · **Optional date:** 2027-06-03 · **Domain resources:** C20 / B15

1. Day / sequence	Global Day 220 of 365; calendar-free M08W4D3; optional date 2027-06-03.
2. Exact topic	Blue-team specialization taster and decision evidence
3. Exact subtopics	SOC analyst, detection engineering, DFIR, cloud security and security engineering roles; evidence from Month 8 projects
4. Learning objective	Compare specialization fit using demonstrated results rather than popularity
5. Primary lecture / reading + direct URL	NIST NICE Workforce Framework `https://www.nist.gov/itl/applied-cybersecurity/nice` **Type:** Framework · **Access:** Free
6. Exact section / lesson locator	NIST NICE Workforce Framework, work roles and task statements. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Microsoft SC-200 certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-operations-analyst/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Score five roles against your project results, interests, programming comfort and local opportunities; choose a top two for Month 10 tasting. **2.** Standard (~2 h): Score five roles against your project results, interests, programming comfort and local opportunities; choose a top two for Month 10 tasting. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Score five roles against your project results, interests, programming comfort and local opportunities; choose a top two for Month 10 tasting. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	specialization-scorecard.csv; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which project result is strongest evidence for your top role? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Scorecard uses evidence and no role is selected only because of prestige or salary assumptions Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "NIST NICE Workforce Framework, work roles and task statements"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup NIST Cybersecurity Framework 2.0; write a five-line correction; retest next morning with a new 10-minute problem.

D221 · M08W4D4 · Month 8 practical examination and milestone gate

Phase: Academic month · **Optional date:** 2027-06-04 · **Domain resources:** B15 / B02

1. Day / sequence	Global Day 221 of 365; calendar-free M08W4D4; optional date 2027-06-04.
2. Exact topic	Month 8 practical examination and milestone gate
3. Exact subtopics	SOC workflow, logs, SIEM, triage, ATT&CK, IR, KQL, Sigma, hunting, DFIR and reporting
4. Learning objective	Demonstrate blue-team competence through an unfamiliar incident simulation
5. Primary lecture / reading + direct URL	Microsoft SC-200 certification page `https://learn.microsoft.com/en-us/credentials/certifications/security-operations-analyst/` **Type:** Official certification page · **Access:** Free learning content; exam price region-based
6. Exact section / lesson locator	Microsoft SC-200 official study guide, skills measured as of 2026; use free materials only. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Complete a 150-minute practical with a synthetic alert, logs, IOC and detection rule; investigate, report and propose a tested detection. **2.** Standard (~2 h): Complete a 150-minute practical with a synthetic alert, logs, IOC and detection rule; investigate, report and propose a tested detection. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Complete a 150-minute practical with a synthetic alert, logs, IOC and detection rule; investigate, report and propose a tested detection. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M8-assessment.pdf and scorecard; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which data source was decisive and what was its limitation? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Score at least 70/100, milestone gate passed, practical at least 18/25 and safety at least 9/10 Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Microsoft SC-200 official study guide, skills measured as of 2026; use free materials only"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Microsoft Sentinel documentation; write a five-line correction; retest next morning with a new 10-minute problem.

D222 · M08W4D5 · Monthly review and gap repairs

Phase: Academic month · **Optional date:** 2027-06-05 · **Domain resources:** B02 / C18

1. Day / sequence	Global Day 222 of 365; calendar-free M08W4D5; optional date 2027-06-05.
2. Exact topic	Monthly review and gap repairs
3. Exact subtopics	SIEM concepts, KQL, detection logic, ATT&CK mapping, incident reporting and evidence handling; active recall
4. Learning objective	Repair Month 8 gaps and prepare cloud/container foundations
5. Primary lecture / reading + direct URL	Kusto Query Language overview `https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric` **Type:** Official language docs · **Access:** Free
6. Exact section / lesson locator	KQL overview and B04 Sigma getting-started review sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	MITRE ATT&CK `https://attack.mitre.org/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: Rework failed assessment items with new queries and test data, update PRJ-11/12, and review basic Linux/Docker prerequisites. **2.** Standard (~2 h): Rework failed assessment items with new queries and test data, update PRJ-11/12, and review basic Linux/Docker prerequisites. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): Rework failed assessment items with new queries and test data, update PRJ-11/12, and review basic Linux/Docker prerequisites. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M8-review.md and retest score; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which detection still lacks a false-positive test and how will you add one? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	Retest score at least 80 percent and every project gap has an issue ticket Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "KQL overview and B04 Sigma getting-started review sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup SigmaHQ; write a five-line correction; retest next morning with a new 10-minute problem.

D223 · M08W4D6 · Network forensics and malware-traffic safety

Phase: Academic month · **Optional date:** 2027-06-06 · **Domain resources:** N07 / B08

1. Day / sequence	Global Day 223 of 365; calendar-free M08W4D6; optional date 2027-06-06.
2. Exact topic	Network forensics and malware-traffic safety
3. Exact subtopics	PCAP triage, DNS/HTTP/TLS metadata, beaconing, file extraction, IOC confidence, isolated analysis and no-sample execution
4. Learning objective	Analyze a legal sample capture without executing any malware
5. Primary lecture / reading + direct URL	Wireshark SampleCaptures `https://wiki.wireshark.org/SampleCaptures` **Type:** Packet capture repository · **Access:** Free
6. Exact section / lesson locator	Wireshark SampleCaptures and N06 Wireshark User's Guide statistics/export sections. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	Malware Traffic Analysis `https://malware-traffic-analysis.net/`
8. Practical task (Core / Standard / Intensive)	**1.** Core (~1 h): complete one minimum instance of: In a disposable VM, analyze one Malware Traffic Analysis or Wireshark sample capture; identify endpoints, protocols, suspicious patterns and confidence limits. **2.** Standard (~2 h): In a disposable VM, analyze one Malware Traffic Analysis or Wireshark sample capture; identify endpoints, protocols, suspicious patterns and confidence limits. Then change one variable, document one error, and save all command output. **3.** Intensive (3-4 h): Standard (~2 h): In a disposable VM, analyze one Malware Traffic Analysis or Wireshark sample capture; identify endpoints, protocols, suspicious patterns and confidence limits. Then change one variable, document one error, and save all command output. Rebuild from a blank file/VM, add one independent extension, consult one primary doc, and write a 150-word teach-back. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	network-forensics.md and sanitized packet evidence; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h · Standard: 2 h · Intensive: 3-4 h.
11. Revision / retrieval exercise	Closed-book: Which metadata supports your hypothesis and what payload data is unavailable because of encryption? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	No sample is executed, findings are packet-backed, and uncertainty is explicit Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "Wireshark SampleCaptures and N06 Wireshark User's Guide statistics/export sections"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup Wireshark User's Guide; write a five-line correction; retest next morning with a new 10-minute problem.

D224 · M08W4D7 · Spaced revision, recovery and Month 9 preview

Phase: Academic month · **Optional date:** 2027-06-07 · **Domain resources:** B03 / CL04 · LIGHT REVISION / CATCH-UP

1. Day / sequence	Global Day 224 of 365; calendar-free M08W4D7; optional date 2027-06-07.
2. Exact topic	Spaced revision, recovery and Month 9 preview
3. Exact subtopics	Log fields, KQL operators, detection lifecycle, ATT&CK and IR phases; active recall and lab cleanup
4. Learning objective	Preserve blue-team knowledge and prepare shared-responsibility thinking
5. Primary lecture / reading + direct URL	SigmaHQ `https://sigmahq.io/` **Type:** Open-source detection rules · **Access:** Free/open-source
6. Exact section / lesson locator	SigmaHQ main documentation and B01 Sentinel overview. No video timestamp is asserted unless visible on the video page.
7. Supplementary resource + URL	AWS Free Tier `https://aws.amazon.com/free/`
8. Practical task (Core / Standard / Intensive)	**1.** Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, archive synthetic logs, delete unneeded cloud resources if any were created, and read AWS Free Tier terms without creating an account — and 10 min evidence. **2.** Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, archive synthetic logs, delete unneeded cloud resources if any were created, and read AWS Free Tier terms without creating an account — and 10 min evidence. Add one variation and one error-log correction. **3.** Light Intensive (~2-3 h): Light Standard (~1.5-2 h): Light Core (~1 h): 20 min retrieval, 20 min minimal practical check — Do a 45-minute retrieval session, archive synthetic logs, delete unneeded cloud resources if any were created, and read AWS Free Tier terms without creating an account — and 10 min evidence. Add one variation and one error-log correction. Add a blank-state repeat and a 100-word teach-back. Still a recovery day. **Safety:** use only synthetic, owned or explicitly authorized data; no public targets.
9. Expected output / evidence	M8-consolidation.md; plus a journal entry or Git commit with date and tool versions.
10. Estimated duration	Core: 1 h (light) · Standard: 1.5-2 h (light) · Intensive: 2-3 h (light).
11. Revision / retrieval exercise	Closed-book: Which cloud responsibility belongs to the customer even when the provider secures the physical infrastructure? Then explain your answer aloud in under two minutes and check against the primary source.
12. Completion criteria	No active billable resources exist and the explanation is correct Evidence saved; safety pass; Core task complete.
13. If assessment fails / targeted revision	If below 70%: revisit the exact locator "SigmaHQ main documentation and B01 Sentinel overview"; use the supplementary resource as an alternate explanation; repeat the practical task with a new input; consult backup CISA Known Exploited Vulnerabilities Catalog; write a five-line correction; retest next morning with a new 10-minute problem.